



Nouredine Kanzari



From Theory to Practice

EBIOS RM Certification Guide

Workshop 1 : Scope & Security Baseline

Workshop 2 : Risk Origins

Workshop 3 : Strategic Scenarios

Workshop 4 : Operational Scenarios

Workshop 5 : Risk Treatment

A Step-by-Step Practical Approach to IT Risk Management

Navigating IT Risk Management with EBIOS RM Methodology

Practical Strategies for Effective IT Risk Management

Exercises with Solutions

About the author



Nouredine Kanzari is a cybersecurity expert with an extensive background in IT risk management and cybersecurity instruction. With a diverse range of certifications that includes being a PECB Certified Trainer, EBIOS Risk Manager, ISO 27005 Senior Lead Risk Manager, ISO 27001 Senior Lead Implementer, ISO 27001 Senior Lead Auditor, Cisco Certified Specialist in Security Core and Enterprise Core, NSE4 Network Security Professional, Palo Alto Instructor, Devops Tools Engineer, LPIC-3 Enterprise Professional Security, LPIC-3 Enterprise Professional Virtualization & High Availability, LPIC-2, LPIC-1, Suse Certified Linux Administration, and a Certified Security Auditor in computer security,

Nouredine Kanzari's professional journey is characterized by a series of impactful roles and accomplishments. Throughout his career, he has held various pivotal positions, including:

Chief Information Security Officer (CISO)

Audit Team Leader

Cybersecurity Instructor

Technical Manager

Training Manager

His extensive experience and leadership have contributed significantly to enhancing cybersecurity practices, risk management strategies, and organizational resilience.

Contents

I.	Risk Management Fundamentals	4
1.	Importance of the Risk Management.....	4
2.	Assets.....	7
3.	Threats	9
4.	Vulnerabilities	16
5.	IT Risk	34
II.	EBIOS RM methodology.....	38
1.	Workshop 1 - Framework and Security Baseline.....	38
2.	Workshop 2 - Risk Sources/Targeted Objectives	40
3.	Workshop 3 - Strategic Scenario	41
4.	Workshop 4 - Operational Scenario	41
5.	Workshop 5 - Risk Mitigation.....	42
III.	Workshop 1 (Scope and Security Baseline)	44
1.	Define the framework of study.....	44
2.	Define the business and technical scope	45
3.	Feared events	52
4.	Security baseline	56
a.	The Scenario approach.....	56
b.	The Compliance approach	56
IV.	Practical exercise 1	63
V.	Practical exercise 2	64
VI.	Practical exercise 3	76
VII.	Practical exercise 4	77
IIX-Workshop II (Risk Origins).....		78
1.	Identify the risk origins and the target objectives.....	79
a.	Identify the risk origins.....	79
b.	Identify the target objectives.....	82

2. Identify the pairs (Risk origin/Target objectives)	87
3. Assessing the pairs (Risk origin/Target objectives)	89
4. Selecting the pairs (Risk origin/Target objectives).....	94
5. Linking the pairs (Risk origin/Target objectives) with Feared events.....	95
IX-Practical Exercise 5	96
X- Practical Exercise 6.....	98
XI-Workshop III (Strategic Scenarios)	100
1. Select the critical stakeholders	100
2. Defining the Strategic scenarios.....	102
3. Defining the Security controls.....	103
XII-Practical Exercise 7	104
XIII-Workshop IV (Operational Scenarios)	106
1. Develop the operational scenario	106
2. Asses the likelihood of operational scenarios.....	108
XIV-Workshop V (Risk Treatment)	109
1. Create a summary of risk scenarios	109
2. Decide the risk treatment strategyand determine controls.....	109
3. Assess residual risks.....	110

I. Risk Management Fundamentals

1. Importance of the Risk Management

Risk management is important for every organization because it plays a crucial role in safeguarding the organization's information, assets, reputation, and overall business operations. Effective risk management ensures the confidentiality, integrity, and availability of the information, preventing data breaches, leaks, or unauthorized access. It helps identify vulnerabilities, assess potential threats, and implement measures to prevent or mitigate these risks, reducing the likelihood of successful cyberattacks.

Risk management helps create strategies to ensure business continuity and quick recovery in the face of IT-related disruptions. It ensures that an organization meets Compliance and Regulatory Requirements, avoiding legal penalties, fines, and reputational damage.

Effective risk management helps maintain customer trust, stakeholder confidence, and brand reputation by demonstrating a commitment to protecting sensitive information.

IT risk assessments provide valuable insights into an organization's technology landscape, helping leadership make informed decisions about technology investments, upgrades, and innovations.

Example:

In this scenario, the bank's assets include customer financial data, account information, transaction records, and internal operational data. Vulnerabilities could arise from outdated software, inadequate firewall configurations, unpatched systems.

The bank's IT risk management team conducts a thorough assessment to identify potential risks. They determine that if a data breach were to occur, it could result in unauthorized access to customer accounts, financial loss, regulatory fines, and damage to the bank's reputation.

The bank implements several risk mitigation strategies:

Firewall and Intrusion Detection Systems (IDS): Upgrades firewall systems and installs IDS to monitor network traffic for suspicious activities and prevent unauthorized access.

Regular Software Updates: Implements a process for regular software updates and security patches to ensure that systems are protected against known vulnerabilities.

Employee Training: Conducts regular cybersecurity training for employees to educate them about phishing threats, social engineering, and safe data handling practices.

Data Encryption: Implements end-to-end encryption for customer data both during transmission and storage to protect against interception and unauthorized access.

Access Controls: Implements strict access controls, ensuring that only authorized personnel have access to sensitive financial data, and enforces strong password policies.

Develops a comprehensive incident response plan: that outlines steps to take in the event of a data breach. This plan includes protocols for containing the breach, notifying affected parties, reporting the incident to regulatory authorities, and communicating with the media to manage the bank's reputation.

Thanks to the proactive IT risk management approach, the bank is better prepared to prevent and respond to data breaches. As a result:

Customer financial data remains secure, enhancing trust and loyalty.

The bank avoids potential financial losses, regulatory fines, and legal actions.

The bank's reputation remains intact, as it demonstrates a commitment to safeguarding customer information.

The bank's operations continue smoothly, with minimal downtime or disruptions.

Risk management is crucial to the success of every company for several important reasons:

Minimizing financial losses: helps a company identify potential risks and take proactive measures to mitigate them. the company can reduce the likelihood and impact of negative events, minimizing financial losses.

Preserving Reputation: Certain risks, such as data breaches can damage a company's reputation. Proper risk management helps maintain a positive public image and trust among customers, investors, and stakeholders.

Compliance and Legal Requirements: Many industries are subject to specific regulations and legal requirements. Failure to manage risks can result in legal actions, fines, and other penalties.

Enhancing Decision-Making: Companies that are aware of potential threats can make informed choices about resource allocation, investment strategies.

Operational Efficiency: Identifying and addressing risks can lead to improved operational efficiency. Reducing vulnerabilities, companies can optimize their operations and reduce wastage of resources.

Without IT risk management business losses can be thought of :

Compromise of Business Functions: This refers to situations where the normal operations and functions of a business are disrupted or compromised (technological failures, cyberattacks, natural disasters, ...). When critical business functions are compromised, it can lead to downtime, decreased productivity, missed opportunities, and potential customer dissatisfaction. Effective IT risk management can help mitigate these risks by ensuring business continuity plans are in place.

Compromise of Business Assets: Business assets include tangible and intangible resources that contribute to the organization's value. Tangible assets can include physical infrastructure, equipment. Intangible assets encompass intellectual property, customer data, proprietary software, and brand reputation. When these assets are compromised, it can result in financial losses, reputational damage, and loss of competitive advantage. IT risk management plays a crucial role in safeguarding these assets by identifying vulnerabilities, implementing security measures, and establishing proper access controls.

Example of how IT risk management can minimize financial losses:

Without IT risk management:

Imagine a technology company that provides an online platform for e-commerce transactions. This platform handles sensitive customer data, including personal information and payment details. Without effective IT risk management:

- ° Hackers identify these vulnerabilities and exploit them to gain unauthorized access to the platform's database.
- ° The data breach exposes sensitive customer information leading to identity theft, fraudulent transactions, and loss of trust among customers.
- ° The company faces legal action and fines due to non-compliance with data protection regulations, such as the General Data Protection Regulation (GDPR).
- ° Decline in customer confidence, which leads to decreased user engagement and revenue.

With IT risk management:

- ° The company implements robust cybersecurity (strong encryption, multi-factor authentication, regular security assessments, and intrusion detection systems, ...)
- ° Employees are regularly trained on cybersecurity best practices to prevent social engineering attacks.
- ° The company develops and tests an incident response plan that outlines immediate actions to take in case of a data breach, including isolating affected systems, notifying affected users.
- ° Customer data is stored and transmitted using strong encryption protocols, reducing the risk of unauthorized access.
- ° The company invests in cyber insurance coverage to mitigate financial losses in case of a data breach.
- ° Independent third-party audits are conducted to assess the company's IT security measures and identify potential vulnerabilities.

The effective risk management starts by understanding critical assets, threats and vulnerabilities.

2. Assets

Refer to any hardware, software, network resources, or digital data that an organization owns or uses to support its IT infrastructure and business operations. Here are some common categories of IT assets along with examples:

Hardware Assets

- **Servers**: Physical machines that host applications
- **Desktop Computers**: Standard workstations
- **Laptops**: Portable computers
- **Storage Devices**: Devices for storing data, such as hard drives, (NAS) systems
- **Printers and Scanners**: Devices for printing and scanning documents

Software Assets

- **Operating Systems**: Software that manages hardware. Example Windows 10
- **Applications**: example Microsoft Office
- **Security Software**: Tools for antivirus, anti-malware, and firewall protection

- **Development Tools:** Software for programming and software development, examples Visual Studio
- **Database:** Software for creating, maintaining, and querying databases. Example Oracle Database, MySQL, Microsoft SQL Server

Network Assets

- **Network Cables:** Ethernet, fiber optic, ..
- **Wireless Access Points:** Devices that enable wireless network connectivity
- **Routers and Switches:** Devices that direct data traffic on a network

Security Assets

- **Firewalls:** Devices or software that protect networks from unauthorized access.
- **Intrusion Detection/Prevention Systems (IDS/IPS):** Tools that monitor and analyze network traffic for potential security breaches
- **Encryption Tools:** Software for encrypting data to ensure confidentiality. Example OpenSSL

Human Assets:

- **Software Developer:** Creates, tests, and maintains software applications. Examples: Java Developer
- **Web Developer:** Specializes in creating websites
- **System Administrator:** Manages and maintains an organization's IT infrastructure
- **Database Administrator:** Manages and maintains databases
- **Chief Information Officer (CIO):** responsible for aligning IT with the organization's goals
- **Information Security Analyst:** Protects an organization's data and information systems from security breaches

Data Assets

Example:

- Disaster recovery plans
- Databases
- emails, images, videos
- logs

3. Threats

Malware:

malicious software designed to disrupt, damage, or gain unauthorized access.

Example: A company employee receives an email with an attachment claiming to be an invoice. Once the attachment is opened, it releases a ransomware virus that encrypts all the files.

Phishing:

involves sending fraudulent emails that appear to be from a legitimate source, aiming to trick recipients into revealing sensitive information or clicking on malicious links.

Example: A bank customer receives an email that appears to be from their bank, asking them to click on a link to update their account information due to a security breach. The link takes them to a fake website that collects their login credentials, allowing the attacker to access their bank account.

Denial of Service (DoS) Attack:

A DoS attack floods a network with excessive traffic, overwhelming its resources and causing it to become unavailable to users.

Example: saturate servers, making a website inaccessible to customers during a major sales event.

Data Breach:

Involves unauthorized access to sensitive or confidential information, potentially leading to its theft, exposure, or misuse.

Example: A healthcare organization's database containing patient records is breached by hackers. The attackers steal personal health information, including names, addresses, medical histories, and social security numbers, which are later sold on the dark web.

Insider Threat:

Individuals within an organization who misuse their access privileges to compromise security.

Example: A disgruntled employee with administrative access to the company's systems intentionally leaks proprietary information to a competitor, causing financial harm and loss of competitive advantage.

Man-in-the-Middle (MitM) Attack:

An attacker intercepts communications between two parties without their knowledge.

Example: An attacker sets up a fake Wi-Fi hotspot in a public place, tricking users into connecting to it. All data transmitted through this hotspot is intercepted and monitored by the attacker, potentially compromising sensitive information.

Social Engineering:

Involves manipulating individuals to divulge confidential information or perform actions that compromise security.

Example: An attacker poses as a technical support representative and calls an employee, claiming there is a critical issue with their computer. The attacker convinces the employee to provide their login credentials, which are then used to gain unauthorized access to the company's systems.

Zero-Day Exploit:

Targets a vulnerability in software before the software's developer releases a fix or patch.

Example: A hacker discovers unknown vulnerability in a web browser and develops an exploit to take advantage of it. They use the exploit to gain unauthorized access to users' computers and steal sensitive data.

Theft of Hardware:

Losing essential hardware could disrupt the business operations, compromise sensitive data, and lead to financial losses.

Example: the thief enters the office and quickly snatches the laptop before anyone notices. The stolen laptop contains sensitive company data, confidential reports, and customer information.

Destruction of equipment:

Depending on the extent of the destruction, the company could face data loss if backups were stored on-site and were also affected by the attack.

Example: The attacker successfully gains unauthorized physical access to the company's data center. They proceed to physically damage servers, network switches, and storage devices, causing a significant disruption in the company's operations.

SQL injection:

The website's login form is vulnerable to SQL injection due to poor input validation.

Example:

User enters his username: john_doe

User enters his password: mysecretpassword

The application constructs an SQL query to check if the provided credentials exist in the database:

```
SELECT * FROM users WHERE username = 'john_doe' AND password = 'mysecretpassword';
```

A malicious user enters the following username: 'john_doe' OR '1'='1' --'

For the password, the malicious user can enter anything or leave it blank

The application constructs the SQL query:

```
SELECT * FROM users WHERE username = 'john_doe' OR '1'='1' --' AND password = '';
```

In this case, the -- is a comment in SQL, causing the rest of the query (including the password check) to be ignored.

The query will always return true because '1'='1' is always true in SQL

As a result, the attacker gains access to the account associated with the username john_doe, even without knowing the correct password.

Brute Force Attack:

An attacker decides to target an account using a combination of a username and password.

Example: The attacker uses automated software or scripts to generate a wide range of possible password combinations. These combinations may include common

passwords, dictionary words, character variations, and different lengths of passwords.

Intercepting sensitive data in transit:

Unauthorized individual capturing and accessing sensitive information while it is being transmitted over a network.

Example: set up a rogue Wi-Fi hotspot with a similar name to the coffee shop's legitimate network. Unsuspecting users might accidentally connect to this rogue hotspot, thinking it's the official network, all the data transmitted over this rogue network is intercepted by the attacker. This includes login credentials, account numbers, and other sensitive information.

USB-Based Threats:

Refer to security risks and vulnerabilities that can arise from the use of USB (Universal Serial Bus) devices, such as USB flash drives, external hard drives.

Example: an employee at a large corporate office finds a USB flash drive lying in the parking lot. Curious about its contents, the employee plugs the USB drive into his office computer to see what's on it. Unbeknownst to them, the USB drive contains malicious software designed to infiltrate the corporate network. When the infected USB drive is plugged into the computer, the malicious software executes a code that exploits a vulnerability in the operating system. The malware spreads across the internal network, scanning for other vulnerable computers and devices connected to the network. The malware steals sensitive data, including proprietary information, customer data, and employee credentials

DNS poisoning:

Malicious user changes the records that a server uses to direct traffic to the right websites. This can cause the DNS server to return the wrong IP address for a given domain name, redirecting traffic intended for a legitimate website to the attacker's website.

Example: a customer of a bank, frequently access the online banking portal to manage his account. In a normal DNS Resolution, he types in the bank's URL (e.g., www.examplebank.com), his computer sends a DNS query to a DNS server to resolve the domain name into an IP address.

In DNS Cache Poisoning: An attacker, through various means, manages to manipulate the DNS response that the computer receives from a compromised DNS server. The attacker's goal is to insert a malicious IP address mapping for the bank's domain. The computer's DNS cache now contains the malicious IP address for the bank's domain. When the user attempts to access the bank's website, his browser is redirected to a fraudulent website that closely resembles the real online banking

portal. The fake banking website prompts to enter the login credentials and other sensitive information. Unaware of the attack, the user provides his username and password.

Botnets:

A botnet is a network of compromised computers, also known as "bots" or "zombies," that are under the control of a malicious actor. These compromised computers are typically infected with malware, allowing the attacker to remotely control them and use their combined power to carry out various cyberattacks. One of the most common uses of botnets is to launch Distributed Denial of Service (DDoS) attacks.

Example: The attacker infects a large number of computers around the world with malware, turning them into bots. These infected computers become part of the botnet and are under the attacker's remote control. The attacker uses a Command and Control (C&C) server to manage and coordinate the actions of the botnet. This server sends instructions to the infected computers, telling them when and how to launch the attack. The attacker selects a target, which could be a website, an online service, or an organization's network. The choice of target might be motivated by financial gain, political reasons. The C&C server sends commands to the infected computers, instructing them to flood the target with a massive volume of traffic. This flood of traffic overwhelms the target's resources, such as its bandwidth, processing power, and memory.

Fake Software:

A fake software contains hidden malware.

Example: A company purchases what it believes to be genuine software licenses from the third-party vendor. The counterfeit software is installed across various departments within the organization, including critical financial systems. Unbeknownst to the company, the fake software contains hidden malware designed to steal sensitive financial data and credentials. The malware activates, infiltrating the company's network, capturing sensitive customer financial data, employee login credentials, and other confidential information.

DHCP Starvation:

An attacker floods the DHCP server with a large number of DHCP requests, depleting the pool of available IP addresses and causing legitimate devices to be unable to obtain addresses.

Example: A corporate network uses DHCP to assign IP addresses to computers, printers, and other devices. The DHCP server has an address pool of 100 IP addresses to assign. An attacker connects a rogue device (like a laptop) to the

network. The attacker configures the rogue device to send a high volume of DHCP requests to the DHCP server, requesting new IP addresses. The rogue device keeps requesting IP addresses in rapid succession, exhausting the DHCP server's available IP addresses.

Fraud:

Manipulation, or misrepresentation for financial gain or other malicious purposes. It encompasses a wide range of tactics and techniques aimed at unlawfully obtaining money, sensitive data, or other valuable assets.

Example: The attacker poses as the executive and sends convincing emails to other employees, clients, or vendors, instructing them to make financial transactions. The attacker might send an email to the finance department requesting an urgent transfer to a fraudulent account. Since the email appears to come from a trusted source, the recipient may follow through with the instructions.

Rogue DHCP Servers:

Unauthorized DHCP servers introduced into the network can assign incorrect or malicious network settings to devices, potentially redirecting traffic to attacker-controlled servers.

Example: The network is set up with a legitimate DHCP server that assigns IP addresses and network configuration to all devices on the network. However, an attacker with malicious intentions manages to connect a rogue device to the LAN. This rogue device has been configured to act as a DHCP server and is designed to distribute IP addresses to other devices on the network. The attacker's goal is to intercept and manipulate network traffic, potentially stealing sensitive information. The rogue device, being a deceptive DHCP server, responds to these DHCP discovery requests with its own DHCP offers. It assigns IP addresses and provides malicious network settings, such as incorrect DNS server addresses or gateway information.

Privilege Escalation:

Is a cybersecurity threat where an attacker exploits vulnerabilities in a system or application to gain higher levels of access and control than they are initially authorized for.

Example: A corporate network with different user roles and access levels. There are regular employees, managers, and administrators, each with varying levels of access to sensitive data and critical systems. The attacker gains initial access to the network by exploiting a known vulnerability in an outdated web server that the company failed to patch. The attacker starts as a regular employee with limited

access to company resources. Through careful exploration and exploitation, he discovered a vulnerability in a file-sharing system used by employees to collaborate on projects. By exploiting this vulnerability, the attacker manages to gain access to a manager's account. He continued to search for vulnerabilities and weaknesses. Eventually, he finds a misconfigured server that allows to execute arbitrary commands with elevated privileges.

Input error:

Refers to a situation where incorrect data is entered into a system or application.

Example: a financial institution that offers online banking services to its customers. Users can transfer money between accounts. A customer intends to transfer \$100 from his savings account to his checking account. However, he accidentally input "\$1000" instead of "\$100" due to a typographical error.

Departure of key person:

A company heavily reliant on the expertise and leadership of the Chief Technology Officer (CTO), who has been instrumental in driving innovation and overseeing crucial development projects. The CTO possesses extensive knowledge about the company's proprietary technologies, trade secrets, and strategic plans. His departure could potentially lead to the loss of critical intellectual property. Competitors or other organizations might try to capitalize on this opportunity.

Alteration of information:

Refers to the unauthorized modification of data, records with the intent to manipulate, or cause harm.

Example: A malicious actor targets a financial institution's database with the intention of altering account balances and transaction records. The attacker gains unauthorized access to the financial institution's internal network through a phishing email that tricks an employee into clicking on a malicious link. Once inside the network, the attacker conducts reconnaissance to identify critical databases. The attacker locates the database containing account balances and transaction records. He uses his access to modify the account balances. To avoid detection, the attacker modifies log files and access records to erase any evidence of his activities.

Repudiation:

Repudiation is an IT threat that occurs when a user denies performing a particular action or transaction.

Example: The user logs into his online banking account and transfers \$1,000 to his friend as a birthday gift. After a few days, the user denies making the \$1,000 transfer and claims that he never initiated or authorized the transaction.

4. Vulnerabilities

The vulnerability refers to a weakness in an information technology (IT) system, software application, network infrastructure, or any digital asset that could be exploited by malicious actors to compromise the confidentiality, integrity, or availability of data, services, or resources.

These weaknesses are often targeted by cybercriminals, hackers, or malicious software (malware) to gain unauthorized access, steal sensitive information, launch attacks, or cause damage to IT systems and assets.

Here are some common IT vulnerabilities:

- Unpatched Software
- Misconfigured Cloud Services
- Weak Passwords
- Inadequate Access Controls
- Outdated Software
- Lack of Encryption
- Flaws in software code
- Lack of network segmentation
- Lack of physical access controls
- Inadequate Backup
- Weak data loss prevention
- Inadequate Monitoring and Logging
- Default Configurations
-

Examples of: (Threat – Vulnerabilities) relationship

Email phishing

Phishing attacks exploits the vulnerability lack of awareness.

Social Engineering

Social engineering attacks exploits the vulnerability lack of awareness.

Distributed Denial of Service (DDoS)

DDoS attacks exploits the vulnerability of limited network resources.

Man-in-the-Middle (MitM) Attack

MitM attacker exploits the vulnerability of unencrypted data.

Zero-Day Vulnerability

Zero-day exploits the vulnerability of unpatched system.

Insider Threats (Data Theft by Employee)

An employee with malicious intent exploits the vulnerability of access control.

Brute Force Password Attack

Brute force exploits the vulnerability of weak passwords.

SQL Injection Attack

Execute unauthorized SQL queries, exploiting the vulnerability of poorly coding practices.

Cross-Site Scripting (XSS)

Inject malicious scripts into web page that is served to other users, when unsuspecting users visit the infected page, the script executes in their browsers exploiting the vulnerability of insecure coding practices.

Unauthorized access

Unauthorized access to sensitive data due to the vulnerability weak access controls.

Fire

Due to the vulnerability Flammable materials stored improperly.

Theft of Hardware

Due to the vulnerability lack of security guards or surveillance.

Water Damage

Due to the vulnerability inadequate water leak detection.

Power Outages

Due to the vulnerability Lack of uninterruptible power supply (UPS).

Equipment Failure

Due to the vulnerability outdated hardware.

Cable Interception

Due to the vulnerability unsecured network closets.

Equipment Malfunction or Overheating

Due to the vulnerability Poor cooling and ventilation.

Failure of telecommunication equipment

Due to the vulnerability of reliance on a single telecommunication provider.

Data Entry Errors

Due to the vulnerability Lack of Validation Checks.

Espionage

Gathering sensitive information due to Inadequate access controls and permission settings.

Spoofing

Trick recipients into opening malicious attachments exploiting the vulnerability leak of awareness.

Tampering

Unauthorized modification exploiting vulnerability weak authentication mechanism.

Elevation of privilege

Gains higher-level access exploiting the vulnerability weak access controls.

Vandalism

Destroying assets exploiting the vulnerability leak in physical access control.

The following table illustrates the relationship between various elements within a security context: threats, their sources, associated objectives, exploited vulnerabilities, and the corresponding impacted assets :

Threat	Source	Source description	Target objective	Exploited Vulnerability	Affected assets
Malware	Hacker	Individual with malicious intent create and distribute malware	° Steal sensitive information ° Gain unauthorized access ° Cause damage	°No awareness : Malware creators often rely on tricking users into performing actions that aid in the installation of malware, such as clicking on malicious links, downloading infected attachments, or disclosing sensitive information °Misconfiguration: Malware can exploit weaknesses in network configurations or protocols to spread laterally within an organization's infrastructure °Not patched software: Malware can leverage these exploits to gain access before a patch is released °Weak Authentication: Malware may target weak passwords or default credentials to gain access to systems °Software Bugs: Malware can exploit flaws in software applications or operating systems. For example, a buffer overflow vulnerability	°Data: Malware can steal sensitive information such as personal data, financial records, intellectual property, and trade secrets. Also malware, can encrypt data and demands payment for its release °Networks: Malware can compromise entire networks, leading to data breaches, unauthorized access, and disruption of services °Devices: Malware can infect individual devices like computers, smartphones, tablets, and IoT devices, potentially leading to data loss or device control °Servers: Malware can compromise servers, leading to data breaches, service disruptions, or unauthorized access °Reputation: Malware can lead to reputational damage for organizations, eroding trust and credibility among customers, partners, and stakeholders °Cloud Services: Malware can target cloud environments, affecting data integrity and availability
	Insider	Malicious actors within an organization may create or deploy malware to achieve personal or organizational objectives			
	Hacktivists	Use malware to advance a particular cause, often by disrupting or exposing the activities of individuals or organizations			
Phishing	Cybercriminal	An individual that engages in illegal activities or unethical behavior using computer systems, networks, and digital technologies	° Stealing Personal Information: attempt to trick individuals into disclosing their usernames, passwords, credit card information, or other personal and financial data. This information can	° Lack of Awareness: Many individuals are not aware of the tactics and techniques used in phishing attacks, making them more susceptible to falling for fraudulent emails, messages, or websites ° Human Psychology: Phishing attacks often manipulate human psychology, relying on factors like curiosity, fear, urgency, or empathy to prompt	° Personal Information: Phishing attacks often aim to steal personal information such as names, addresses, phone numbers, Social Security numbers, and other sensitive data ° Email Accounts: Phishing attacks can result in unauthorized access to email accounts, allowing attackers to send malicious emails from the victim's
	Nation-State Actors	State-affiliated groups that gather intelligence, conduct			

		espionage, disrupt infrastructure	be used for identity theft, financial fraud, or other malicious purposes	victims to take actions they wouldn't under normal circumstances	account, distribute spam, or gain access to sensitive information contained in emails
	Hacktivists	An individual or group of individuals who employ hacking techniques and digital activism to promote social, political, or ideological causes	° Credential Theft: target login credentials for various online accounts, such as email, social media, and e-commerce platforms.	° Weak Authentication Processes: If a service or platform has weak authentication processes, attackers may attempt to phish for login credentials to gain unauthorized access	° Financial Information: Attackers may attempt to gather credit card numbers, bank account details, and other financial information to conduct unauthorized transactions
	Insider	Malicious actors within an organization	° Data breaches: ransomware attacks, or other cybersecurity incidents	° Lack of Security Awareness Training: Individuals who haven't received proper cybersecurity training are more likely to fall victim to phishing attacks	° Network Access: Phishing attacks can provide attackers with access to an organization's internal network, enabling them to infiltrate systems, install malware
	Competitor	Refers to an individual that actively engages in various forms of online activities with the intention of gaining a competitive advantage, causing harm, or achieving specific goals within the digital realm. These activities can include cyber espionage, hacking, data breaches, denial-of-service attacks	° Distributing malicious content, including viruses, ransomware, spyware, and other types of malware	° Browser Vulnerabilities: Some phishing attacks exploit vulnerabilities in web browsers to display fake content or prompt users to download malicious software	° Reputation: Phishing attacks can damage an individual's or organization's reputation if attackers use compromised accounts to spread false information, engage in malicious activities
	Scammer	Use various tactics, such as phishing emails, fake websites, social engineering, and other forms of digital manipulation to exploit unsuspecting victims for personal gain, often leading to financial loss or compromising personal data	° Fraud: Phishers may impersonate legitimate individuals or organizations to deceive recipients into taking actions that benefit the attacker. This can include sending fake invoices, requesting payments, or redirecting funds to fraudulent accounts		° Intellectual Property: In business settings, attackers may target intellectual property, trade secrets, research, and development data through phishing attacks
	Extremist Groups	Refers to a collection of individuals or entities that employ digital platforms, techniques, and technologies to promote and advance their extremist ideologies, often advocating for radical political, social, or			° Employee Accounts: Phishing attacks targeting employees can lead to compromised internal accounts, which can be used for further attacks within an organization

		religious beliefs. These groups utilize the internet and various online mediums to spread propaganda, incite violence, engage in hacking activities, and disrupt digital systems, with the intent of furthering their extremist agendas			
DoS	Hacktivists		° Disruption: The attacker aims to disrupt the availability and accessibility of the target system or service, making it difficult or impossible for legitimate users to access the resources they need ° Resource Exhaustion: DoS attacks often consume critical resources such as bandwidth, processing power, memory, or storage, causing the target system to become slow ° Financial Impact: In some cases, attackers may target online businesses or services, hoping to disrupt their operations and cause financial losses due to downtime or decreased customer trust ° Reputation Damage: Extended downtime or unavailability can lead to a loss of trust among users, customers, partners, and stakeholders ° Competitive Advantage:	° Application Design Flaws: Poorly designed applications might be vulnerable to attacks that can crash or hang the application, affecting its availability ° Server Misconfiguration: Taking advantage of improperly configured servers or services, which can lead to resource depletion or system instability ° Lack of Redundancy: targeting systems with no redundancy or failover mechanisms can disrupt the service's availability more easily ° not been patched by the vendor or system administrator ° Protocol Vulnerabilities: Exploiting weaknesses in network protocols (e.g., TCP, UDP) or application-layer protocols (e.g., HTTP, DNS) to manipulate or consume resources in an unintended way	° Websites and Online Services: A DoS attack can target websites, making them inaccessible to legitimate users. Online services, such as email servers, cloud platforms ° Network Infrastructure: Routers, switches, and other networking equipment can be overwhelmed by a DoS attack, leading to network congestion and slowdowns ° Servers: Web servers, application servers, and database servers can be overloaded by a DoS attack, causing them to become unresponsive or crash ° Reputation: Organizations can face reputational damage if customers or users cannot access their services, leading to frustration and loss of trust
	Cybercriminal				
	Competitor				
	Nation-State Actors				

			Attackers might target competitors' systems or services to gain a competitive advantage by disrupting their operations		
Data Breach	Hacktivists		° Data Theft or Espionage: Attackers may aim to steal sensitive or valuable information, such as personal data, financial records, trade secrets, or intellectual property ° Financial Gain: Some unauthorized access attacks are motivated by financial gains. Attackers may attempt to compromise financial systems, online banking accounts, or payment card information to conduct unauthorized transactions, steal funds ° Disruption: Attackers may target systems with the goal of causing disruption or chaos. This can involve disrupting critical infrastructure, services, or operations, which can lead to financial losses, reputational damage ° Data Manipulation or Destruction: Attackers might seek to alter, manipulate, or delete data within a system, potentially causing data loss, system malfunctions, or creating false information ° System Compromise:	° Weak Authentication and Access Controls: Many assets come with default usernames and passwords that are often left unchanged, making them an easy target for attackers ° Weak Passwords: Weak, easily guessable, or commonly used passwords are susceptible to brute force attacks ° Lack of Multi-Factor Authentication (MFA): Without MFA, stolen or compromised credentials provide direct access to the asset ° Improper User Privileges: Insufficient segregation of user roles and permissions can allow unauthorized users to gain elevated access ° Unpatched or Outdated Software: Failing to apply security patches and updates leaves assets exposed to known vulnerabilities ° Legacy Systems: Older software or systems may not receive updates, making them susceptible to exploits ° Weak Firewalls and Intrusion Detection Systems: Poorly configured or outdated security appliances can allow unauthorized traffic ° Open Ports and Services: Unused or unnecessary ports and services may provide an entry point for attackers ° Unencrypted Data: Data transmitted or stored without encryption can be intercepted and read by unauthorized parties ° Human Exploitation: Attackers can manipulate individuals into divulging sensitive information or	
	Cybercriminal				
	Competitor				
	Nation-State Actors				

			Some unauthorized access attacks aim to gain control over systems or networks for malicious purposes. Attackers might create backdoors or establish control over the compromised system, allowing them to launch further attacks ° Cyber Espionage: Nation-states or other groups might engage in unauthorized access attacks to gather intelligence, monitor communications, or infiltrate government or corporate networks for political, military, or economic reasons ° Reputation Damage: Attackers may breach a system to steal sensitive or embarrassing information with the intent of damaging an individual's or an organization's reputation ° Intellectual Property Theft: Unauthorized access attacks can be targeted at stealing valuable intellectual property, including software code, research data, proprietary algorithms, and product designs	granting unauthorized access ° Unauthorized Physical Access: Lack of physical security measures can lead to direct tampering with assets ° Improper Configurations: Incorrectly configured security settings can lead to unintended vulnerabilities ° Inadequate Data Protection: Improper handling of sensitive data can lead to unauthorized access	
Man-in-the-Middle (MitM)	Hacktivists		° Sensitive Information Theft: MitM attacks can also target encrypted communications to steal	° Weak Encryption or No Encryption: If the communication between parties is not encrypted or is encrypted using weak algorithms, attackers can intercept and read the data being transmitted	° Email: MitM attacks can compromise email communication, giving attackers access to email contents, attachments, and potentially allowing them to send malicious emails on behalf of the victim
	Hacker				
	insider				

	Cybercriminal		encryption keys or certificates, allowing the attacker to decrypt and access sensitive information	◦ Insecure Protocols: Some protocols, like HTTP instead of HTTPS, are susceptible to interception. Attackers can exploit this by intercepting unencrypted traffic and injecting malicious content ◦ Unauthenticated Connections: Lack of proper authentication mechanisms allows attackers to establish connections with parties involved and pose as legitimate entities ◦ Unverified Certificates: If a party doesn't verify the authenticity of certificates during SSL/TLS handshakes, attackers can present fake certificates to intercept encrypted ◦ Router Vulnerabilities: Exploiting vulnerabilities in routers or switches can give attackers control over network traffic	◦ Web Traffic: Attackers can intercept HTTP, HTTPS, and other web traffic, potentially gaining access to sensitive information such as login credentials, personal data, and financial details ◦ Network Communications: MitM attacks can target various types of network communication, including Wi-Fi networks, Ethernet connections ◦ Internet of Things (IoT) Devices: MitM attacks can target IoT devices, allowing attackers to control or manipulate these devices, leading to privacy breaches or disruptions
	Intelligence Agencies	Government agencies may use MitM attacks as part of lawful interception activities to monitor communications for criminal or national security purposes.	◦ Bypassing Security Measures: MitM attacks can be used to bypass security mechanisms like two-factor authentication or encryption, allowing the attacker to gain unauthorized access to systems or data		
	Nation-State Actors		◦ Credential Theft: MitM attacks can target authentication processes to steal login credentials (e.g., usernames and passwords). Attackers can then use these credentials to access accounts, systems, or networks and carry out further malicious activities ◦ Session Hijacking: By intercepting and taking control of an ongoing communication session (such as a web session or a user's login session), the attacker can gain unauthorized access to an account or system ◦ Data Manipulation: The attacker can modify the content of the intercepted communication before passing it along to the intended recipient. This could involve altering transaction details, messages, or instructions to		

			cause confusion, financial losses		
Social Engineering	Hacktivists		Information Gathering: Attackers may use social engineering techniques to gather sensitive or confidential information, such as usernames, passwords, financial data, or other personal details	- Lack of Awareness: People who are unaware of the potential risks and tactics used in social engineering are more likely to fall victim to such attacks - Lack of Training: Insufficient training in recognizing social engineering tactics can make employees more susceptible to manipulation - Poor Password Practices: Individuals using weak passwords, reusing passwords, or sharing them with others can inadvertently provide attackers with access - Lack of Multi-Factor Authentication (MFA): Without MFA, attackers who obtain a user's password may gain easy access to accounts and systems - Lack of Security Culture: Organizations without a strong security culture may have employees who are less vigilant about security risks	- Confidential Information: Attackers can manipulate individuals to reveal sensitive information such as passwords, login credentials, personal identification numbers (PINs), and access codes - Personal Identity: Attackers can steal personal information for identity theft, which may lead to financial loss, fraudulent activities, or reputational damage - Reputation and Brand Image: Manipulating individuals or employees into disclosing information that could harm a company's reputation or compromise its brand image - Human Resources: Attackers can target human resources departments to obtain employee information, payroll data, or other sensitive HR-related information - Operational Processes: Attackers can manipulate employees into altering normal operational processes, potentially leading to disruptions, data breaches, or financial losses - Healthcare Information: Social engineering attacks can compromise the confidentiality of patients' medical records, leading to privacy breaches and potential misuse of sensitive health data
	Hacker				
	insider				
	Cybercriminal				
	Corporate Espionage	Competing companies or individuals seeking to gain an edge in business may use social engineering to extract proprietary information, trade secrets, or intellectual property from their rivals	Unauthorized Access: Social engineering attacks can aim to gain unauthorized access to systems, networks, or physical locations by tricking individuals into divulging security credentials		
	Challenge Seeker	Some individuals engage in social engineering for the thrill of testing their skills or curiosity about what they can achieve	- Data Theft: Social engineering attacks may be aimed at stealing valuable data, trade secrets, intellectual property, or any other form of digital or physical assets - Fraud and Financial Gain: Social engineering can also be used to perpetrate various types of fraud - Identity Theft: Some social engineering attacks involve impersonating individuals to steal their identities, which can lead to further financial fraud and privacy violations - Espionage: State-sponsored or corporate espionage can involve social		

			engineering to infiltrate organizations, gain insider information, or compromise national security		
Zero-Day Exploit	Criminal Organizations	These groups may engage in activities like hacking into financial systems, stealing personal information, or conducting large-scale cyberattacks	° Unauthorized Access ° Data Theft ° Espionage ° Sabotage ° Financial Gain ° Reputation Damage ° Cyber Warfare	° Software Bugs: Zero-day exploits often target software bugs, such as buffer overflows, memory corruption, race conditions, and input validation errors ° Operating System Vulnerabilities: Zero-day exploits can target vulnerabilities in operating systems, such as privilege escalation flaws, kernel-level vulnerabilities ° Vulnerabilities in network services, such as remote desktop protocols, web servers, and email servers, can be exploited to gain unauthorized access or execute arbitrary code on the target system ° weaknesses in authentication and authorization mechanisms, allowing attackers to bypass security measures and gain unauthorized access ° convincing users to perform actions that inadvertently expose vulnerabilities. For example, a user might be tricked into clicking a malicious link or opening a malicious attachment ° Vulnerabilities in server software, such as web servers (e.g., Apache, Nginx), database servers (e.g., MySQL, PostgreSQL), and application servers	° Network Infrastructure: Routers, switches, firewalls, and other network infrastructure components may be targeted to gain control over a network or to intercept and manipulate traffic ° Applications: Any software applications that are commonly used, such as office suites, media players, communication tools, and more, could be targeted via zero-day exploits ° Embedded Systems: Embedded systems found in various devices, such as medical equipment, automotive systems, and industrial control systems, can also be targeted ° Virtualization Software: Hypervisors and virtualization platforms are potential targets ° Cloud Services: Vulnerabilities in cloud service platforms and providers can lead to unauthorized access to sensitive data stored in the cloud
	Security Researchers	may discover and use zero-day exploits for legitimate purposes, such as identifying vulnerabilities, testing and improving security measures, and helping organizations enhance their defenses			
	Nation-States	Some countries and government agencies may develop or purchase zero-day exploits as part of their cyber espionage or cyber warfare efforts			
	Cybercriminals	These are individuals or groups with malicious intent who seek to exploit zero-day vulnerabilities for financial gain, data theft, disruption of services, or other malicious activities			
Theft of Hardware	Criminals and Opportunistic Thieves	These are individuals who engage in theft for personal gain. They might steal IT hardware such as laptops, smartphones, and servers to sell on the black market	° Monetary Gain: Stolen IT hardware, such as laptops, servers, and networking equipment, can be sold on the black market for a profit	° Lack of Physical Security: Insufficient physical security measures, such as unlocked doors, unmonitored access points, or lack of surveillance cameras, can make it easier for thieves to gain access to IT hardware	° Physical Hardware: Stolen IT hardware includes items such as laptops, desktop computers, servers, routers, switches, and other network equipment ° Data and Information: Stolen hardware might contain sensitive or confidential data, such as customer

	Insiders	Employees or contractors within an organization may steal IT hardware due to disgruntlement, financial incentives, or other personal reasons	° Data Breaches: Thieves might steal IT hardware to gain access to sensitive data stored on the devices ° Resale or Use: Some thieves may steal IT hardware for personal use or to sell to unsuspecting individuals	° Unattended Equipment: Leaving IT hardware unattended, especially in public spaces or unsecured areas, creates an opportunity for theft ° Inadequate Employee Training: Lack of training and awareness among employees about security risks and protocols can lead to carelessness and inadvertent theft ° Untracked Inventory: Poor inventory management and tracking can make it difficult to detect missing hardware until it's too late ° Inadequate Monitoring: Lack of real-time monitoring for unusual activities or unauthorized access can delay the detection of theft ° Unsecured Storage: Leaving laptops, tablets, or other portable devices in vehicles or unsecured storage areas can make them easy targets for theft ° Disposal of Equipment: Insecure disposal practices can lead to theft if hardware containing sensitive data is not properly wiped or destroyed ° Unsecured Peripherals: Peripherals such as external hard drives, USB drives, and printers can be stolen if left unsecured ° Lack of Deterrents: Visible deterrents such as security cameras, locks, and signage can discourage potential thieves	information, financial records, intellectual property, trade secrets, and proprietary software ° Network Infrastructure: Theft of network equipment can disrupt an organization's network infrastructure, affecting connectivity, communication, and data flow ° Reputation: If stolen hardware contains sensitive or personal information, a data breach could lead to a loss of trust among customers, partners, and stakeholders. This damage to the organization's reputation can have far-reaching consequences
	Hacktivists				
	Competitors				
	Terrorist Groups	terrorist organizations might steal IT hardware to support their activities or gather information for planning attacks	° Sabotage: Theft of IT hardware can disrupt the operations of a business, organization, or individual. By stealing critical hardware components like servers or networking equipment, thieves can cause significant downtime and financial losses		
Destruction of equipment	Malicious Hackers	Cybercriminals and hackers may intentionally destroy IT equipment as part of a cyberattack	° Sabotage and Disruption: Attackers may seek to disrupt the operations of an organization	° Uncontrolled Access: Unauthorized access to IT equipment can result in intentional or accidental damage, theft, or tampering ° Environmental Factors: Poor environmental conditions, such as extreme temperatures, humidity, dust, or inadequate cooling, can lead to overheating or corrosion of IT equipment components ° Insufficient Maintenance: Lack of regular maintenance, cleaning, and updates can lead to the	° Data and Information: IT equipment often stores critical data and information ° Hardware Assets: The IT equipment itself, including servers, computers, networking devices, and peripherals, is a valuable asset ° Software Assets: IT equipment may host software applications and licenses ° Network Assets: Networking equipment, such as
	Insiders	Employees, contractors, or individuals with authorized access to IT systems may cause equipment destruction due to various reasons, including revenge, sabotage,	° Revenge or Retaliation: Individuals or groups with grievances against an organization may resort to destroying IT equipment as a form of retaliation. This		

		or personal motivations	could be due to personal conflicts, legal disputes, or other disagreements ° Competitive Advantage: In some cases, attackers may aim to gain a competitive advantage by crippling the IT infrastructure of a rival organization ° Ideological Reasons: Certain attackers, such as hacktivists or cyberterrorists, may engage in destructive actions to promote a particular ideology	gradual deterioration and eventual failure of IT equipment	routers, switches, and firewalls, are essential for communication and data transfer within an organization ° Operational Assets: Many businesses rely on IT equipment to carry out daily operations. Destruction of IT equipment can disrupt business processes ° Reputation and Brand Assets: IT disruptions caused by the destruction of equipment can lead to negative customer experiences, loss of trust
	Terrorists	terrorist groups may target IT infrastructure to disrupt critical services, communication networks, or government operations			
	Vandalism	Random acts of vandalism or mischief can also lead to the destruction of IT equipment, particularly in unsecured locations			
SQL injection	Hackers		° Unauthorized Data Access: Attackers may use SQL injection to bypass authentication and gain unauthorized access to sensitive data stored in a database ° Data Exfiltration: Once attackers gain access to the database, they can extract data from it and steal sensitive information. This stolen data can then be used for identity theft, financial fraud, or other malicious purposes ° Data Manipulation: SQL injection can allow attackers to alter, delete, or modify data within the database ° Privilege Escalation: By	° Lack of Input Validation: When an application does not properly validate user inputs, attackers can inject malicious SQL code into input fields, leading to unauthorized access to the database ° Error Messages Disclosure: If error messages from the database are displayed directly to users, attackers can exploit these messages to gain insights into the database structure and use that information to craft malicious SQL queries ° Inadequate Authentication and Authorization: SQL injection attacks can also exploit weaknesses in authentication and authorization mechanisms, allowing attackers to access or modify data they shouldn't have access to	° Application and Server Compromise: In severe cases, attackers may be able to exploit SQL injection vulnerabilities to take control of the application or underlying server, potentially leading to a complete system compromise ° Sensitive Operations: SQL injection can be used to perform operations that can lead to financial loss, such as transferring funds, altering transaction records ° Data: An attacker can gain unauthorized access to sensitive data stored in a database, including personal information, financial records, passwords, and other confidential data. Attackers can modify or delete data stored in the database. SQL injection attacks can lead to denial-of-service (DoS) scenarios by overwhelming the database server with malicious queries, causing it to become unresponsive or crash
	Hacktivists				
	Competitors				
	Insiders				
	State-Sponsored Actors				

			exploiting SQL injection vulnerabilities, attackers may be able to escalate their privileges within the database system. This could enable them to perform actions they wouldn't normally have permission to do, such as creating new users, modifying access controls ° Denial of Service (DoS): In some cases, attackers may use SQL injection to execute malicious queries that cause the database or application to become unresponsive or crash ° Application Defacement: SQL injection attacks might also be used to modify the content displayed by a web application. Attackers could inject malicious scripts or content into a website, potentially defacing it ° Malware Injection: In more sophisticated attacks, attackers might inject malware or malicious code into the database, which could then be executed within the context of the database server ° Lateral Movement: If the database server is part of a larger network or environment, attackers could potentially use a successful SQL injection attack as a		
--	--	--	---	--	--

			stepping stone to pivot within the network and move laterally to other systems ° Reputation Damage: Successful SQL injection attacks can lead to significant reputational damage for organizations		
Brute Force	Hackers		° Password Cracking: Brute force attacks are commonly used to crack passwords ° Account Takeover: Attackers may use brute force attacks to gain control over user accounts on various platforms, such as email accounts	° Weak passwords: If a system has users with weak passwords, such as common words, easily guessable patterns, or short lengths, it becomes vulnerable to Brute Force Attacks ° Lack of account lockout or rate limiting: Without mechanisms in place to prevent multiple failed login attempts within a short period of time, attackers can keep trying different passwords until they find the correct one	° Network Services: Network services like Remote Desktop Protocol (RDP), SSH, and FTP can be compromised if weak passwords are used ° Network Services: Network services like Remote Desktop Protocol (RDP), SSH, and FTP can be compromised if weak passwords are used ° Data: Brute force attacks can be used to attempt to gain access to confidential information
	Criminal Organizations				
	State-Sponsored Actors				
	Hacktivists				
	Insiders				
	Script Kiddies	Inexperienced individuals who use pre-made hacking tools or scripts to engage in attacks, including brute force attacks, without a deep understanding of the underlying mechanisms	° Network Access: Brute force attacks can target network devices, routers, and firewalls in an attempt to gain unauthorized access to a corporate network ° Software Cracking: Brute force attacks can also be used to crack software license keys or activation codes	° Insufficient password complexity requirements: Systems that do not enforce strong password policies, including requirements for a mix of characters (uppercase, lowercase, numbers, symbols) and a minimum length, are more susceptible to Brute Force Attacks ° Insufficient password complexity requirements: Systems that do not enforce strong password policies, including requirements for a mix of characters (uppercase, lowercase, numbers, symbols) and a minimum length, are more susceptible to Brute Force Attacks ° Lack of multi-factor authentication (MFA): Systems without MFA are more vulnerable to Brute Force	

				Attacks because even if an attacker guesses the password, they would still need the second factor to gain access	
USB-Based Threats	Cybercriminals Hacktivists Hackers insiders		° Data Theft: Attackers may use USB threats to steal sensitive data, such as personal information, financial details, intellectual property, or trade secrets ° Malware Propagation: USB devices can serve as a vector for spreading malware, such as viruses, worms, Trojans, and ransomware, from one system to another ° Espionage: In targeted attacks, USB threats can be used for corporate or government espionage. Attackers may physically insert USB devices into a target organization's network to gather sensitive information ° Destruction or Disruption: Some USB threats aim to disrupt computer systems or networks	° Autorun and AutoPlay Exploitation: USB devices can take advantage of autorun and AutoPlay features to automatically execute malicious code when connected to a computer ° Lack of Device Authentication: Some systems do not properly authenticate USB devices, allowing attackers to plug in rogue devices that can then execute malicious commands ° Outdated Software: If a system's operating system or software has known vulnerabilities, connecting a malicious USB device could trigger an exploit against those vulnerabilities	° Computers and Laptops: USB threats can target the operating system, applications, and data stored on computers and laptops ° Servers: USB attacks can impact servers in data centers or local networks, potentially causing data breaches ° Networks: USB threats can be used to spread malware across networks, enabling attackers to gain control over networked devices, infiltrate systems ° Sensitive Information: USB threats can target sensitive data, including personal information, financial data, intellectual property, and other confidential information

DNS poisoning			° Data Exfiltration: DNS can be used as a covert channel for sending sensitive data out of a compromised network. Attackers can encode data into DNS queries or responses and send them to a controlled server outside the network, bypassing traditional security controls ° Disruption of Services: By poisoning DNS records, attackers can cause legitimate users to be unable to access specific websites or online services ° Espionage and Surveillance: DNS poisoning can be used for surveillance purposes, redirecting specific users or organizations to malicious servers that log their activities or capture sensitive information	° Lack of Source Authentication: DNS was originally designed without strong authentication mechanisms, making it susceptible to attackers who can impersonate legitimate DNS servers and send false DNS responses ° Cache Pollution: DNS caching servers often do not perform proper validation of received DNS responses, making them susceptible to accepting and storing malicious or forged responses ° Insufficient DNSSEC Implementation: DNS Security Extensions (DNSSEC) help protect against DNS poisoning by digitally signing DNS records ° Slow Cache Expiration: Longer cache expiration times can increase the potential impact of DNS poisoning attacks	° Websites: Legitimate websites can be redirected to malicious sites, leading to potential data theft, phishing, or malware distribution ° Email Services: DNS poisoning can redirect email traffic, leading to interception of sensitive emails or distribution of spam ° Network Resources: DNS poisoning can disrupt access to internal network resources, affecting business operations and communication ° DNS Servers: The DNS servers themselves can be compromised, leading to further propagation of malicious DNS information
Fake Software	Malware creators		° Malicious Intent: gain unauthorized access to a user's system, steal sensitive information	° Lack of User Awareness: Many users are not well-informed about the risks associated with downloading and installing software from untrusted sources	° Computers and Devices: Fake software can infect computers, smartphones, tablets, and other devices ° Data and Information: Malicious software can steal,

			° Financial Gain: Cybercriminals often distribute fake software as a means to generate revenue. They may use tactics like scareware, where a fake software claims to have detected threats on the user's system and demands payment for their removal ° Phishing: Fake software can also be used as a part of phishing campaigns. Cybercriminals may create fake software updates or applications that mimic legitimate ones to trick users into downloading and installing them. These fake programs can then be used to gather sensitive information ° Espionage: Nation-states and other entities may develop and deploy fake software to conduct espionage activities ° Sabotage: In some cases, fake software may be installed to disrupt the normal functioning of a system or organization	° Outdated Software and Security Patches: Running outdated software and failing to apply security patches can leave systems vulnerable to exploitation. Attackers may take advantage of known vulnerabilities in outdated software to install fake software ° Weak Passwords and Credentials: Poor password practices can lead to unauthorized access to accounts and systems. Cybercriminals who gain access to a user's account can manipulate software downloads and install fake applications	corrupt, or delete valuable data, including personal files, financial records, passwords, and more ° Networks and Infrastructure: Fake software can compromise network security, leading to potential breaches of entire systems, servers, and databases ° Operational Disruption: Organizations may face operational disruptions due to fake software, leading to downtime, data loss, and potential financial losses
--	--	--	---	---	---

5. IT Risk

Risk is the likelihood of a threat exploiting a vulnerability, resulting in a negative impact on an organization's operations, assets, or objectives. Risk is the likelihood that a loss will occur. Some risks are so severe, Other risks are minor and can be accepted. We must differentiate severe risks from minor risks, when this is done properly, administrators and managers can intelligently decide what to do about any type of risk. The end result is one option of:

- Avoid the risk
- Transfer the risk
- Mitigate the risk
- Accept the risk

Company that ignores risk can fail. Risk can be mitigated by reducing vulnerabilities or reducing the impact.

The concept of risk in the context of risk management is often represented as the product of likelihood and impact. This approach helps quantify and prioritize risks by considering both the probability of an event occurring (likelihood) and the potential consequences if it does occur (impact). The formula for calculating risk is:

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

For example, if we have a risk event with a high likelihood (70% chance) and a high impact (potential financial loss of \$1 million), the calculated risk would be:

$$\text{Risk} = 0.70 \text{ (likelihood)} \times \$1,000,000 \text{ (impact)} = \$700,000$$

Or

For example, if we have a risk event with a high likelihood (4) and a high impact (3), the calculated risk would be:

$$\text{Risk} = 4 \text{ (likelihood)} \times 3 \text{ (impact)} = 12$$

The following sentences develop some Risk scenarios identification:

High Impact Scenarios :

Risk 1: A phishing threat, initiated through a deceptive email containing a malicious link, exploited the vulnerability of human susceptibility to social engineering, leading to the compromise of employee workstations and sensitive data. This compromise could lead to identity theft, and potential financial losses.

Risk 2: The infiltration of ransomware into the server infrastructure stemmed from a compromised software update, exploiting an unpatched vulnerability, and resulting in the encryption of critical business data. This infiltration led to financial losses and damage the organization's reputation.

Risk 3: The compromise of the customer database due to lack of access control, could result in loss of customer trust, legal consequences and financial penalties.

Risk 4: The disruptive impact on the web server and online services due to a DDoS attack could lead to loss of revenue, damage to the organization's online presence, and customer dissatisfaction.

Risk 5: Unauthorized access to sensitive cloud storage could lead to exposure of confidential documents, potential legal consequences, and damage to the organization's reputation.

Risk 6: Unauthorized manipulation of financial transactions and data could lead to financial losses, regulatory fines, and legal liabilities for the organization.

Risk 7: The exposure of customer payment information through an SQL injection attack could result in financial fraud, identity theft, and loss of customer trust.

Risk 8: The compromise of a user's computer and personal data due to a zero-day exploit could result in data theft, unauthorized access to accounts, and potential financial losses.

Risk 9: The divulgence of user credentials and sensitive information through a social engineering attack could lead to unauthorized access, data breaches, and potential financial losses for individuals and the organization.

Medium Impact Scenarios :

Risk 10: An external hacktivist group successfully defaced the company website temporarily, leading to a moderate loss of credibility and necessitating rapid restoration efforts to mitigate potential brand damage.

Low Impact Scenarios :

Risk 11: A minor malware infection affected a non-critical system due to a user's inadvertent download of a malicious file, causing only isolated disruption and minimal data loss.

Risk 12: A Temporary service interruption occurred as a result of a misconfiguration error in network equipment settings, causing brief disruption but with negligible financial impact.

Risk 13: Unauthorized access to publicly available information took place due to misconfigured cloud storage with public access, leading to limited data exposure and no compromise of sensitive information.

The following table provides information for the previously listed IT risk scenarios:

Risk	Threat	Actor	Exploited vulnerability	Impact	Impact Severity
Phishing Attack on Employee Workstations	Phishing	Hacker	Lack of awareness	Data breaches, identity theft, potential financial loss	High
Ransomware Targeting Server	Ransomware	External attacker	Unpatched software vulnerability	Disrupted operations, financial loss, reputation damage	High
DDoS Attack on Web Server	DDoS Attack	Cyber terrorist	Lack of adequate network traffic filtering	Revenue loss, online presence damage, customer dissatisfaction	High
Malware Infection Through Unpatched Software	Malware	Insider	Unpatched software vulnerability	Identity theft, unauthorized account access, data loss	High
Unauthorized Access to Cloud Storage	Unauthorized access	Malicious actor	Insecure authentication methods	Confidential data exposure, legal consequences	High
Insider Attack on Financial Transactions	Insider attack	Insider	Insufficient role-based access controls	Financial losses, regulatory fines, legal liabilities	High
SQL Injection Attack on E-Commerce Database	SQL injection	External attacker	Lack of input validation and sanitization	Financial fraud, identity theft, loss of customer trust	High
Zero-Day Exploit in Web Browser	Zero-day exploit	Hacker	Unknown vulnerability in the web browser	Data theft, unauthorized access, potential financial loss	High
.....					

In the IT Infrastructure, we can examine risks in the following domains:

User:

Phishing and Social Engineering: Users may fall victim to phishing emails or social engineering tactics, leading to unauthorized access to sensitive data or system compromise.

Weak Passwords: Users using weak passwords or reusing passwords across multiple accounts can lead to unauthorized access and data breaches.

Insider Threats: Malicious actions or unintentional mistakes by employees with access to sensitive information can result in data leaks or security breaches.

Lack of Security Awareness: Users not being educated about security best practices could inadvertently engage in risky behavior, such as clicking on malicious links or downloading infected files.

Workstation:

Malware and Viruses: Workstations can become infected with malware or viruses, potentially leading to data loss, unauthorized access, or system disruption.

Unpatched Software: Failure to apply security patches and updates can leave workstations vulnerable to known vulnerabilities.

Data Leakage: Improper data handling practices on workstations can lead to accidental data leakage or breaches.

Unauthorized Access: Weak access controls can result in unauthorized users gaining access to workstations and sensitive information.

Network:

Data Interception: Weak network security can allow attackers to intercept and eavesdrop on data transmissions.

Denial of Service (DoS) Attacks: Networks can be targeted with DoS attacks, causing service disruptions and downtime.

Unauthorized Access: Insufficient network access controls can lead to unauthorized users gaining access to network resources.

Network Segmentation Issues: Poorly segmented networks may allow attackers to move laterally within the network, increasing the scope of a breach.

Application:

Code Vulnerabilities: Flaws in application code can be exploited by attackers to gain unauthorized access or execute malicious actions.

SQL Injection: Poorly sanitized inputs can lead to SQL injection attacks, allowing attackers to manipulate databases.

Unvalidated Inputs: Lack of input validation can lead to data integrity issues and potentially allow attackers to insert malicious data.

Inadequate Authentication: Weak authentication mechanisms can lead to unauthorized access to applications and data.

II. EBIOS RM methodology

EBIOS RM (Expression of Needs and Identification of Security Objectives - Risk Management) is a comprehensive risk analysis and management methodology for information security developed in France.

It provides a structured approach to identifying, assessing, and mitigating security risks within an organization. EBIOS RM focuses on five key workshops that guide the risk analysis process from initial scoping to risk treatment and ongoing monitoring.

1. Workshop 1 - Framework and Security Baseline

- Identify the organizational context, security objectives, and constraints.
- Define the scope of analysis, including assets, processes, and systems.
- Identify feared events and their severity.
- Establish a security baseline with minimum required security measures.

Example:

Step 1: Context and Objectives

Key Stakeholders: Chief Information Security Officer (CISO), IT Director, System Manager, Compliance Officer.

Their Role and responsibilities: Assess and manage the information security risks related, ensuring data confidentiality and system availability.

Stakeholders	Workshop 1	Workshop 2	Workshop 3	Workshop 4	Workshop 5
CEO	Decision-maker	Decision-maker			Decision-maker
Manager	contributor	contributor	contributor	contributor	contributor
RSSI	animator	animator	animator	animator	animator
Compliance Officer	consultant	consultant			consultant
.....					

	CEO	Manager	RSSI	Compliance Officer	
Task 1: Define the context	A	R		/	
Task 2: Identify assets	A	R		/	
Task 3: Establish a baseline	A	R		C	
Task 4: Identify risk sources	A	R		C	
Task 5: Define objectives	A	R		C	
Task 6: Combine risk sources with targeted objectives	A	R		C	
Task 7: Identify feared events	A	R		C	
Task 8: Identify impact	A	R		C	
Task 9: Develop strategic scenarios	A	R		/	
Task 10: Develop operational scenarios	A	R		/	
Task 11: Evaluate risks	A	R		C	
Task 12: Prioritize risks	A	R		C	
Task 13: Propose security measures	A	R		/	
Task 14: Develop an action plan	A	R		/	
.....					

A: approving

R: realization

C: consultant

....

Step 2: Scope Definition

Health's electronic medical records (EMR) system, including patient records, medical history, treatment plans, and associated IT infrastructure;

Assets: patient database, user accounts, medical imaging files, access control systems

Step 3: Security Baseline:

ISO 27001 Requirement (Baseline Security Measure):

Security Baseline	Clause	Requirement	Deviation	Risk
ISO 27001 Requirements	Access Control (Clause A.9.1)	The organization shall control access to information systems	some users have elevated access privileges	risk of unauthorized access to sensitive patient data
.....				

2. Workshop 2 - Risk Sources/Targeted Objectives

- Identify potential risk sources, both internal and external.
- Define objectives to be safeguarded against identified risks.

Example:

Step 1: Identify Risk Sources

External Hacking

Insider

Competitor

Cyber Terrorist

.....

Step 2: Define Targeted Objectives

Objective 1: Gain unauthorized access to customer financial data for identity theft and fraud

Objective 2: Exploit security weaknesses to manipulate transactions for financial gain

Objective 3: Disrupt operations and customer services

Step 3: Align Risk Sources Objectives

External Hacking → Gain unauthorized access to customer financial data for identity theft and fraud.

Cyber Terrorist → Disrupt operations and customer services.

This alignment provides valuable insights into potential motivations and goals of attackers, which helps inform the subsequent workshops and the development of effective security measures to mitigate these risks.

3. Workshop 3 - Strategic Scenario

- Develop scenarios by combining risk sources with targeted objectives.
- Identify potential sequences of events leading to risk situations.
- Analyze consequences of scenarios on security objectives.

Example:

Scenario 1: Hackers breach the company's payment portal, the impact: Financial loss due to potential legal fines and customer compensation (impact: high)

Scenario 2: Hackers threaten to leak the data unless a ransom is paid, the impact: Damage to the company's reputation, resulting in decreased customer trust (impact: high)

Scenario 3: A disgruntled employee gains unauthorized access to the payment system, the impact: Data compromise leading to potential legal and regulatory consequences (impact: high)

4. Workshop 4 - Operational Scenario

- Detail strategic scenarios into specific operational scenarios.
- Analyze precise sequences of actions leading to security incidents.
- Identify vulnerabilities and existing security measures.

Example:

Due to limited server capacity, the Hacker launches a DDoS attack by flooding the website with a massive volume of traffic.

The website's servers become overwhelmed, leading to degraded performance and eventual downtime.

Customers trying to access the website during the sale event experience slow page loading or inability to complete transactions.

5. Workshop 5 - Risk Mitigation

- Evaluate risks based on likelihood and potential impact.
- Prioritize risks according to severity and organizational importance.
- Propose security measures to mitigate identified risks.
- Develop an action plan for implementing security measures and continuous risk monitoring.

Example:**Step 1: Risk Evaluation**

Operational Scenario: Unauthorized access to online banking accounts due to weak authentication measures.

Risk Assessment:

Likelihood: High (frequent attempts by attackers).

Impact: Very High (potential financial loss, reputational damage).

Risk Level: Critical (High Likelihood and Very High Impact).

Step 2: Risk Prioritization

Rationale: Given the critical risk level, this scenario requires immediate attention.

Risk Mitigation Strategy:

Strengthen authentication mechanisms (multi-factor authentication, CAPTCHA, etc.).

Implement intrusion detection and prevention systems.

Conduct regular security awareness training for users.

Step 3: Risk Mitigation Measures

Measures:

Enhanced Authentication: Implement multi-factor authentication (MFA) for all online banking users.

Intrusion Detection and Prevention: Deploy robust intrusion detection and prevention systems to monitor and block suspicious activities.

User Education: Develop a comprehensive security awareness program for customers, educating them about safe online practices and recognizing phishing attempts.

Step 4: Implementation Plan

Timeline: Roll out enhanced authentication within the next three months. Intrusion detection and prevention systems to be operational within six months.

Responsibilities: IT department for technical implementation, Security team for user education.

Resources: Budget allocation for technology procurement, HR resources for user education materials.

III. Workshop 1 (Scope and Security Baseline)

EBIOS helps organizations identify and analyze risks associated with their information systems, and it provides a structured approach for managing those risks.

EBIOS is divided into several workshops, each designed to guide practitioners through different stages of risk assessment and management. Workshop 1 is the initial stage of the EBIOS methodology and focuses on the identification of assets, threats, vulnerabilities, and impacts.

Here's an overview of Workshop 1 in the EBIOS risk methodology:

1. Define the framework of study

The first phase of the EBIOS risk methodology is called "Define the framework of study" This phase involves setting the foundation and context for the risk assessment process. It establishes what the study aims to achieve (objectives of the study) and Who should be involved in the study (their role and responsibilities).

Example:

The X Bank objective is to conduct a comprehensive risk assessment of its new e-Banking application to identify potential security vulnerabilities and threats that could impact the confidentiality, integrity, and availability of customer data and financial transactions.

The Key stakeholders involved in the risk assessment include:

IT Department: Responsible for providing technical information about the application's architecture and components. It Provides detailed information about the application's infrastructure, network, and technologies.

Security Team: Responsible for analyzing security controls and identifying potential vulnerabilities. The team Identifies potential security risks, assesses vulnerabilities, and proposes countermeasures.

Legal Team: Ensures compliance with data protection and privacy laws. Ensures that the assessment adheres to relevant data protection regulations and legal requirements.

Operations Team: Provides insights into the operational aspects of the application. Offers insights into application deployment, maintenance, and monitoring.

Management: Responsible for approving risk mitigation strategies and allocating resources. Approves the risk assessment plan, reviews assessment results, and allocates resources for mitigation.

2. Define the business and technical scope

Business asset

Include processes and information. Business assets are often given higher protection priority due to their direct impact on the organization's success and continuity.

Example:

Customer database: It directly contributes to the bank's core business (managing customer accounts)

Contracts and Agreements: Legal agreements with customers, partners, and suppliers

Innovation Roadmaps: Plans for introducing new products, technologies

Business Plans: Long-term and short-term strategies for growth, expansion, and development

Equipment and Machinery: Technical specifications, maintenance schedules, and operational guidelines

Electronic Health Records: store patient medical histories, lab results

Formulas and Designs: give the company a competitive edge.

Student Data: Information about students

Sales Process: This process involves selling products to customers

Customer Service Process: This process focuses on addressing inquiries, issues, and complaints

Human Resources (HR) Process: This process includes recruitment, hiring, onboarding and training employee

Financial Process: This process involves managing the company's financial resources. It includes budgeting, financial reporting, expense tracking, financial analysis

Quality Process: This process ensures that products meet specified quality standards. It involves quality inspections, testing, process improvement

Project Management Process: This process involves planning, executing, and controlling projects to achieve specific goals. It includes defining project scope, setting milestones, allocating resources

Legal and Compliance Process: This process ensures that the company operates within legal and regulatory frameworks. It includes compliance monitoring, legal documentation, intellectual property protection

Supporting asset

supporting assets refer to the resources that enable the functionality of business assets

Here are some examples of supporting assets:

Firewalls: protect the business assets from unauthorized access

Server: Example, the server supports the availability of the database (business asset) by hosting it and ensuring that it is accessible to authorized users

Data Storage Infrastructure: Without a robust storage solution, the company cannot store, manage, or retrieve customer data efficiently

Network Infrastructure: The network infrastructure includes all the hardware, software, and protocols that facilitate communication and data exchange between various components of the organization

UPS: provides temporary power to devices in the event of a power outage

IDS: monitors network traffic and system behavior to identify and alert about potential security breaches

Workstation: provides employees with a Workstation device to perform their tasks and access business applications

Application: used to manage various business processes, such as finance, human resources

Relationship: Business asset (Processes/Information) / Supporting asset (Hardware/Software/Network/Personnel)

Business Asset	Type (Processe/Information)	Description	Responsible	Supporting Assets	Description
Customer Information	Information	Personal and financial data of customers	HR	Customer Database	This database holds all the customer-related data. It includes sensitive details such as names, addresses, contact information, purchase history, and possibly payment information. The database requires robust security measures to prevent unauthorized access or data breaches

				Application Server	The application server hosts the software applications used to manage and process customer information. It may also handle authentication and authorization, ensuring only authorized personnel can access the data
				Network Infrastructure	The network infrastructure connects all components and enables data flow between them. It includes routers, switches, firewalls, and other network devices. Securing the network is crucial to prevent unauthorized access and data interception
				Storage Systems	These systems store the data, including the customer information. Proper encryption, access controls, and backup strategies are essential to protect against data loss and unauthorized access
Human Resources Process	Process	The set of activities related to HR management	RH	HR Server	The server hosting HR data and applications
				Network	The network infrastructure for HR processes
				Application	HR software application
				Server Operating system	Windows 2019 Server
Quality Control Process	Process	Process to ensure products/services meet quality standards	Quality responsible	Personnel	Executing quality control activities, conducting inspections, and reporting findings
				Backup Systems	Ensuring data and records related to quality control are securely stored and retrievable
				Application	Providing a software platform for managing and documenting quality control activities
				Communication Systems	Facilitating real-time communication among quality control stakeholders

Define the scope

Start by identifying the organization's assets, such as data, equipment, applications, and processes. This will help you understand what needs to be protected.

Document the final scope of study, indicating the assets included, the security issues identified and the reasons for the inclusion or exclusion of certain elements.

Present the scope of study to management and stakeholders for validation and approval. Ensure that all parties involved are in agreement with the chosen scope.

Example of Scope 1: database management

Identification of critical assets (assets that must be protected).

Databases: The data stored in the database, such as customer information, financial transactions, etc.

Servers: The physical servers hosting the database

Applications: Applications using the database to access and manipulate data

Users: Users authorized to access the database and perform operations

Sensitive data: Confidential or sensitive information stored in the database

Process Identification

Processes are the activities that impact assets. In this scenario, the processes could include:

Database access: The processes for authenticating and authorizing users to access the database.

Data manipulation: The processes of reading, writing, modifying and deleting data in the database.

Backup and recovery: The processes for regularly backing up data and restoring it in the event of a failure.

Access Rights Management: The processes for managing user permissions to control their access to data

Identification of stakeholders

Stakeholders are entities that have an interest in the security of the system. In this scenario, stakeholders could include:

Asset Owner: The person or entity responsible for the database management system.

System administrators: The people responsible for managing and maintaining the system.

Application Developers: People who create and maintain applications using the database.

End Users: The individuals who use the applications and access the data in the database

Perimeter delimitation

Using the information collected in the previous steps, you can define the scope of your security analysis for the database management system. For example, you might decide that the scope includes databases, servers, applications, authorized users, and data access and manipulation processes. Backup and restore processes could also be included, as they impact data availability.

Validation

Validate the identified perimeter with stakeholders and subject matter experts to ensure accuracy and completeness.

Documentation

Document the identified perimeter, including the assets within scope, the boundaries.

Example of Scope: e-commerce Scope

The scope of study encompasses the computer system used by the e-commerce company to manage its online operations. This includes hardware and software components, networks, databases, web servers, order processing applications, online payment systems. The scope covers all stages of the e-commerce process, from the selection of products by customers to the delivery of goods.

Included:

- Hardware and software infrastructure of the computer system.
- Databases containing product, customer and order information.
- Web servers and associated applications for managing online transactions.
- Online payment systems and payment processing mechanisms.

Exclude:

Information systems used for internal business operations that are not directly related to e-commerce.

Perimeter justification:

The scope has been defined to specifically target critical components and processes related to e-commerce. This definition of the scope will allow a targeted assessment of information security risks that could affect the availability, integrity and confidentiality of the company's e-commerce operations.

Example of Scope 2: Human Resources Management System

Includes all processes, data and technologies related to the management of human resources within the organization. This includes databases containing employee information, payroll modules, time tracking systems, performance management tools.

Included Resources: Included resources are sensitive employee data, payroll information, employment contracts, performance reviews, Servers, databases, and applications used to manage this information.

Business asset		Associated supporting assets
RH	Recruitment	Recruitment application, HR Server
	Employee management	Human Resources Management Application, HR Databases, HR Server
	Training management	Training Management Application, HR Server
	Leave management	Leave tracking application, HR server
	Pay	Payroll Application, HR Server

Identifying and prioritizing assets to protect is a critical step in defining the scope. This process involves understanding your organization's business objectives, evaluating the value of assets, assessing potential threats and vulnerabilities, and determining the potential impact of risks. Here's a detailed approach to help you identify and prioritize assets for protection:

Understand Business Objectives:

Start by gaining a thorough understanding of your organization's business goals, objectives, and critical processes. Identify the key activities that drive your business and the assets that support them.

Inventory Assets:

Create an inventory of all IT assets within your organization. This includes hardware, software, databases, networks, applications, intellectual property, customer data, financial records, and more. Consider both physical and digital assets.

Categorize Assets:

Categorize assets based on their criticality to business operations, sensitivity of data, and their impact on the organization's overall mission. Common categories include financial, operational, customer-related, and intellectual property assets. Consider factors such as financial impact, operational disruption, legal and regulatory consequences, reputational damage, and customer trust.

Consider Legal and Regulatory Requirements:

Identify any legal and regulatory requirements that mandate the protection of specific assets. This could include industry-specific regulations (e.g., HIPAA, GDPR) or general data protection laws.

Engage Stakeholders:

Involve key stakeholders, including business units, IT teams, legal, compliance, and senior management, in the asset identification and prioritization process. Their insights will help ensure a comprehensive and accurate assessment.

3. Feared events

A "feared event" is an event that impact the confidentiality, integrity and availability of the business asset.

Example: data breach

Confidentiality Impact:

A data breach occurs when an attacker gains unauthorized access to a company's customer database containing sensitive personal information, including names, addresses, social security numbers, and credit card details. This breach compromises the confidentiality of customer data, potentially exposing it to malicious actors. The impact could include identity theft, financial fraud, legal actions, and damage to the company's reputation.

Integrity Impact:

Upon breaching the database, the attacker alters customer transaction records, modifying purchase amounts and delivery addresses. This compromise in data integrity results in incorrect order fulfillment, leading to customer complaints, financial discrepancies, and erosion of trust in the company's systems and services.

Availability Impact:

As a result of the breach, the company's e-commerce platform experiences a Distributed Denial of Service (DDoS) attack. The attack overwhelms the network infrastructure, causing the website to become unavailable for several hours. The unavailability of the website disrupts customer shopping experiences, leads to lost sales, and negatively impacts the company's revenue and customer satisfaction.

A "feared event" refers to a significant and potentially harmful incident that an organization wants to prevent.

A feared event could be:

- Malicious actor gains unauthorized access to sensitive customer information (This could include personally identifiable information (PII) such as names, addresses, social security numbers)
- Attacker encrypts critical data and demand a ransom for its release
- Attacker sends emails aimed at tricking employee into revealing confidential information

- Attacker overloads an organization rendering network or system inaccessible to users and affecting operations
- Attacker Exploits of software vulnerabilities that have not been properly patched, leading to unauthorized access
- Attacker Manipulates of individuals to disclose sensitive information, passwords, or access credentials through psychological tactics
- ...

Impact

The term "impact" refers to the potential consequences or effects of a threat event on an organization's assets. It can be:

Financial Impact: The potential monetary losses due to a threat event

Reputation Impact: The damage or harm that could be inflicted upon an organization's reputation, credibility, and public perception

Legal Impact: The legal consequences, liabilities, and legal actions that an organization might face due to a threat event

Operational Impact: The disruptions that may occur within an organization's day-to-day operations as a result of a threat event

Business Continuity Impact: The interruption to an organization's ability to continue its business functions

How Feared event impacts a business asset

Examples:

- A ransomware attack (feared event) compromises sensitive data (business asset) resulting in reputational damage
- Malware infection spreading across internal network (feared event) impacts confidential documents (business asset)
- Theft of company laptops (feared event) lead to disclosure of sensitive data (business asset) stored on them
- A data breach (feared event) exposes credit card information (business asset)
- Malicious modification (feared event) alters critical files (business asset)
- A cybercriminal tricks an employee to transfer his password (feared event) to disclosure a sensitive data (business asset)

Severity Matrix

Here is how the severity matrix is usually defined in the EBIOS context:

G1 - Very Low Severity (No significant):

- ° No significant impact on information security.
- ° The incident has a low financial, operational, or reputational impact.
- ° Little or no business disruption.

G2 - Low Severity (Minor):

- ° Minor impact on information security.
- ° The incident may result in modest costs or slight disruption.
- ° May affect certain activities, but without major consequences.

G3 - Medium (Significant) Severity:

- ° Significant impact on information security.
- ° The incident may result in significant costs or major disruptions.
- ° Can seriously affect business and reputation.

G4 - High Gravity (Major):

- ° Major impact on information security.
- ° The incident may have serious financial, operational or reputational consequences.

	Impact
G4	° Major impact on information security. ° The incident may have serious financial, operational or reputational consequences.
G3	° Significant impact on information security. ° The incident may result in significant costs or major disruptions. ° Can seriously affect business and reputation.
G2	° Minor impact on information security. ° The incident may result in modest costs or slight disruption. ° May affect certain activities, but without major consequences.
G1	° No significant impact on information security. ° The incident has a low financial, operational, or reputational impact. ° Little or no business disruption.

Example:

Scenario	Business asset	Feared event	Impact	severity
A ransomware attack (feared event) compromises sensitive data (business asset) resulting in reputational damage	sensitive data	ransomware attack	Reputational damage	G4
Malware infection spreading across internal network (feared event) impacts confidential documents (business asset)	Malware infection	confidential documents	Sensitive Data disclosure	G4
Theft of company laptops (feared event) lead to disclosure of sensitive data (business asset) stored on them	sensitive data	Theft of company laptops	Sensitive data disclosure	G4
A data breach (feared event) exposes credit card information (business asset)	credit card information	data breach	Data breach	G4
Malicious modification (feared event) alters critical files (business asset)	critical files	Malicious modification	Illegal modification	G4
Business Continuity Impact: The interruption to an organization's ability to continue its business functions	A business process	interruption	Process disruption	G4
An external hacktivist group successfully defaced the company website temporarily	Web site management	Defacement web site	Web defacement	G2
A minor malware infection affected a non-critical system due to a user's inadvertent download of a malicious file, causing only isolated disruption and minimal data loss	Non-critical system	Malware infection	disruption	G1

4. Security baseline

a. The Scenario approach

The scenario approach aims to identify and address intentional risks, such as potential attack scenarios and threats from malicious parties. Based on the information gathered in the compliance approach, identify potential attack scenarios. For example, an attacker could attempt to access sensitive data through a phishing attack.

b. The Compliance approach

EBIOS RM is based on two approaches, compliance approach and scenario approach. The compliance approach would assess how current security measures compare to the requirements of the standards. This would allow deviations from legal requirements to be identified, and specific actions to be taken to comply with applicable regulations. The scenario approach would be appropriate as it would simulate different situations and scenarios of potential attacks. For example, you might consider scenarios such as an SQL injection attack, a denial of service (DDoS) attack, or data theft through security vulnerabilities. By identifying these scenarios, you can develop specific risk management plans for each case, putting in place preventive security measures and incident response plans.

Example:

Stage 1 (Approach by Compliance): a company that handles sensitive financial information. It chooses the PCI DSS standard (Payment Card Industry Data Security Standard) as a benchmark for the security of payment card data. The company identifies a gap: “although passwords are required, there is no password complexity requirements policy in place.” This puts the company at risk of account compromise.

Stage 2 (Scenario Approach): The organization could consider an attack scenario where an attacker tries to guess weak passwords to access financial accounts. Potential impact of this attack could include payment card data theft and financial fraud

By using these two approaches together, the company can obtain a complete view of information security risks. The compliance approach helps identify weaknesses against established security requirements, while the scenario approach helps conceptualize how those weaknesses might be exploited in real-world situations. This allows the company to take proactive steps to mitigate risk and strengthen its overall security.

By using these two approaches in a complementary way, you can simultaneously address unintended risks (by compliance) and intentional risks (by scenario) to ensure a comprehensive and balanced approach to information security risk management in your system.

The compliance approach:

Focuses on identifying and managing risks by comparing existing security measures with security requirements defined by benchmarks or standards.

Provides a clear framework for the selection and implementation of security measures. Based on recognized security benchmarks or standards, organizations can identify best practices and relevant security controls to put in place to protect their assets and achieve security objectives.

Many organizations are subject to specific information security regulations and standards, such as personal data protection (such as GDPR in Europe) or industry standards. The compliance approach ensures that the security measures put in place comply with these legal and regulatory requirements

By identifying the gaps between current security practices and compliance requirements, the compliance approach helps highlight potential risks. This helps organizations prioritize actions to take to reduce risk and strengthen security in a targeted manner.

The compliance approach facilitates communication with internal and external stakeholders, such as management, employees, customers and business partners. It demonstrates the organization's commitment to information security and builds trust by showing that adequate measures are in place to protect assets

The compliance approach helps to reduce uncertainties and subjective interpretations in the implementation of security measures. Based on recognized benchmarks, organizations have a clear roadmap for selecting and implementing security controls

The steps of the compliance approach in the EBIOS method:

- Understanding the issues, the assets to be protected
- Choose the relevant security baselines or standards that will serve as the basis for assessing compliance. For example, you could choose ISO 27001, NIST SP 800-53, or other standards specific to your industry
- Analyze the gaps between the existing measures and the security recommendations of the standards
- Identify potential risks arising from gaps between current security measures and compliance requirements

- Assess risks taking into account identified impact on the organization's assets
- Develop an action plan to address vulnerabilities and compliance gaps. This plan may include additional security measures
- Implement the necessary security measures to achieve compliance with the chosen standards
- Perform periodic audits and assessments to ensure that security measures are maintained and adapted to changes

To protect assets many standards, laws and regulations are in place. Companies must comply with them. Compliance with IT standards, such as ISO 27001, NIST, HIPAA, and GDPR, is crucial for companies operating in the technology and information security domains.

Here's why adherence to these specific IT standards is important:

- **Data Security and Privacy:** IT standards like ISO 27001, NIST, HIPAA, and GDPR provide guidelines and controls for protecting sensitive data, ensuring its confidentiality, integrity, and availability. Compliance helps companies establish robust data security and privacy practices, reducing the risk of data breaches, unauthorized access, and non-compliance with privacy regulations.
- **Regulatory Compliance:** Each of these standards has legal and regulatory implications. For instance, GDPR applies to companies handling personal data of European Union citizens, HIPAA regulates the healthcare industry in the United States, and NIST provides cybersecurity guidelines endorsed by the U.S. government. Compliance with these standards helps companies avoid legal penalties, fines, and reputational damage.
- **Risk Management:** IT standards offer frameworks for risk assessment and management. They help companies identify vulnerabilities, assess threats, and implement appropriate security controls. By following these standards, organizations can proactively manage risks and strengthen their overall security posture.
- **Global Business Opportunities:** Many international companies and clients require their partners and vendors to comply with recognized IT standards. Adhering to these standards can open doors to global business opportunities and partnerships, as it demonstrates a commitment to best practices and security.
- **Customer Trust and Reputation:** Companies that comply with IT standards signal their dedication to safeguarding customer data and information. This fosters customer trust, strengthens the company's reputation, and can lead to improved customer loyalty and retention.

- Incident Response and Recovery: IT standards often include guidance on incident response and disaster recovery planning. Companies that follow these guidelines are better equipped to handle cybersecurity incidents, minimize downtime, and recover more quickly from disruptions.
- Competitive Advantage: Demonstrating compliance with recognized IT standards can differentiate a company in a competitive market. It can give the company a competitive advantage by showcasing its commitment to security, privacy, and quality.
- Innovation and Continuous Improvement: IT standards often encourage a culture of continuous improvement and innovation. Organizations that adopt these standards are more likely to stay updated with the latest technological advancements and best practices in the IT field.

Here's an overview of each of the mentioned standards and the types of activities for which they can be used:

ISO 27001 (International Organization for Standardization 27001):

Is an international standard for information security management systems (ISMS). It provides a systematic approach to managing information security risks and protecting sensitive information.

Use: ISO 27001 can be used by organizations of all sizes and industries to establish, implement, maintain, and continually improve an ISMS. It's suitable for any activity involving the management of information security risks and the protection of data.

NIST (National Institute of Standards and Technology) Framework for Improving Critical Infrastructure Cybersecurity:

The NIST Cybersecurity Framework offers guidelines for managing and reducing cybersecurity risks. It provides a flexible framework that can be customized to an organization's risk tolerance and business needs.

Use: The NIST Framework is applicable to organizations across various sectors and sizes. It is suitable for activities involving the assessment, enhancement, and communication of cybersecurity practices and risk management.

HIPAA (Health Insurance Portability and Accountability Act):

HIPAA establishes regulations for the protection of sensitive health information, including patient records and medical data. It aims to ensure the privacy and security of healthcare information.

Use: HIPAA is specifically relevant to the healthcare industry, including healthcare providers, health plans, and healthcare clearinghouses. It is used to safeguard patient data and ensure compliance with privacy and security regulations.

GDPR (General Data Protection Regulation):

GDPR is a comprehensive data protection regulation that applies to organizations processing personal data of individuals in the European Union. It emphasizes data protection, privacy, and individuals' rights.

Use: GDPR is applicable to organizations that process personal data of EU residents. It is used to ensure the lawful processing of personal data, protect individual rights, and manage cross-border data transfers.

FISMA (Federal Information Security Management Act):

FISMA is a U.S. federal law that mandates information security standards and practices for federal government agencies and their contractors. It focuses on protecting federal information and systems.

Use: FISMA is used by U.S. federal government agencies and contractors to establish and maintain information security programs, manage risks, and ensure the security of federal information systems.

SOX (Sarbanes-Oxley Act):

SOX is a U.S. federal law that mandates corporate accountability and transparency in financial reporting. It aims to prevent financial fraud and protect investors.

Use: SOX is relevant to publicly traded companies in the United States. It is used to establish internal controls, ensure accurate financial reporting, and promote accountability among company executives.

GLBA (Gramm-Leach-Bliley Act):

GLBA is a U.S. federal law that requires financial institutions to protect the privacy and security of customers' nonpublic personal information.

Use: GLBA is used by financial institutions such as banks, credit unions, and securities firms to safeguard customer information, maintain privacy practices, and comply with data security requirements.

PCI DSS (Payment Card Industry Data Security Standard):

PCI DSS is a set of security standards established to ensure the protection of payment card data. It was developed by major credit card companies, including Visa, MasterCard, American Express, Discover, and JCB, to provide a unified framework for securing payment card transactions and sensitive cardholder information.

Use: PCI DSS is applicable to any organization that stores, processes, or transmits payment card data, including merchants, service providers, financial institutions, and other entities involved in payment card transactions.

Example:

Référence de Contrôle de l'Annexe A	Contrôle	Situation actuelle	Écart identifié	Impact	severity	Mesures correctives
A.9.2 Gestion des accès utilisateurs	La gestion des accès utilisateurs doit être mise en œuvre pour accorder l'accès aux systèmes d'information et aux services en fonction des besoins de l'utilisateur, des responsabilités de l'utilisateur et des risques pour l'organisation	Dans le système actuel de l'organisation, l'accès aux données médicales sensibles est basé sur des identifiants de connexion (nom d'utilisateur et mot de passe) uniquement. Les utilisateurs ont des privilèges d'accès étendus par défaut, sans distinction entre les niveaux de responsabilité ou les types de données auxquelles ils ont accès	L'écart par rapport à cette mesure de contrôle réside dans le fait que l'accès aux données de santé n'est pas géré en fonction des besoins spécifiques des utilisateurs, de leurs responsabilités et des risques potentiels pour l'organisation. De plus, l'absence d'authentification à deux facteurs compromet la sécurité de l'accès	Cela peut entraîner un risque accru de divulgation non autorisée de données médicales sensibles, ainsi qu'une difficulté à suivre et à contrôler les accès aux informations médicales	G3	Mettre en place une gestion des accès utilisateurs basée sur les rôles et les responsabilités, en attribuant des privilèges d'accès spécifiques en fonction des besoins de chaque utilisateur Implémenter une authentification à deux facteurs pour renforcer la sécurité de l'accès aux données sensibles de santé Mettre en œuvre un processus de revue périodique des accès pour s'assurer que les autorisations restent appropriées et en ligne avec les responsabilités de chaque utilisateur
.....						

IV. Practical exercise 1

Exercise:

Imagine that you work for a financial services company that processes sensitive information about its customers' financial transactions. Your security officer has requested a risk assessment to ensure the security of this data. You will use the compliance approach of the EBIOS method to identify security gaps and propose remedial measures.

Solution:

Step 1: Identification of security needs

Example: Security needs include protecting sensitive customer financial transaction data, preventing leaks of confidential information, and ensuring continuous availability of financial services.

Step 2: Select a standard

ISO 27001 is chosen as a standard to guide the risk assessment, due to its reputation for best practices in information security management.

Step 3: Comparison with security requirements

Gap: ISO 27001 requires a strong password management policy to be in place. However, the company currently allows employees to use simple passwords like "123456"

Step 4: Identification of vulnerabilities and risks

The lack of a strong password management policy puts customer accounts at increased risk of brute force attacks, where attackers could try thousands of combinations to gain access to accounts.

Step 5: Risk assessment

In the event of a successful brute force attack, customer accounts could be compromised, which could lead to theft of funds and financial loss

Step 6: Action plan

Implement a strong password management policy that requires the use of passwords containing at least eight characters, including upper and lower case letters, numbers, and special characters. Users will also need to renew their passwords every 90 days.

V. Practical exercise 2

Exercise:

You work for an e-commerce company that sells various products online. The company operates a website where customers can browse products, place orders, and make payments. The company also stores customer information, including names, addresses, and payment details. Your task is to define the context for an information security risk assessment using the EBIOS RM methodology.

Solution:

Objectives:

Identify and assess information security risks associated with the e-commerce website, customer database, and payment processing system.

Develop a comprehensive set of security measures to mitigate identified risks.

Ensure compliance with relevant regulations and standards (e.g., GDPR, PCI DSS).

Roles and Responsibilities:

Workshop 1: Context Definition

Stakeholders:

CEO

CISO

Business Owner

IT Manager

Data Protection Officer (DPO)

Security Expert

Legal team

Roles and Responsibilities:

CEO: Provide high-level strategic direction and support for the EBIOS RM project. Approve the objectives and scope of the project. Ensure alignment of project goals with overall business strategy. Emphasize the significance of information security and risk management in achieving the company's goals and protecting its assets. Provide a clear understanding of the organization's strategic priorities, business objectives, and risk tolerance.

CISO: Assist in identifying key security concerns and priorities. Help define the technical scope and security baseline. collaborates with other stakeholders to define clear objectives for the EBIOS RM process. These objectives may include ensuring the security and confidentiality of sensitive data, maintaining business continuity, and protecting the organization's reputation. allocates necessary resources, including budget, personnel, and tools, to support the successful execution of the EBIOS RM project. Ensures that the project has the necessary support to achieve its goals. identifies and engages key stakeholders who should be involved in the EBIOS RM process, including representatives from IT, legal, compliance, and business units. establish the organization's risk tolerance level, which guides the assessment and treatment of risks identified during the EBIOS RM process. reviews and approves the overall approach to the EBIOS RM process, ensuring it is in line with industry best practices and the organization's security strategy.

Business Owner: Define and communicate the business objectives and priorities for the EBIOS RM project. Identify critical business processes and assets to be included in the scope. Collaborate on identifying potential feared events and business impact. Shares the business objectives, priorities, and potential impacts related to the scope of the study.

IT Manager: Provide technical insights into the organization's IT infrastructure and systems. Define the technical scope and limitations of the project. Contribute to the identification of potential technical vulnerabilities. Provides technical insights into the organization's IT infrastructure, systems. Assist in identifying potential feared events related to data breaches and privacy violations.

DPO: Ensure the project considers data protection and privacy regulations. Collaborate on establishing the security baseline for protecting sensitive data. Emphasizes data privacy and protection concerns, clarifies legal and regulatory requirements.

Security Expert: Contribute specialized security knowledge to identify potential security risks and threats. Assist in identifying potential feared events from a security perspective. Help determine the initial security baseline and recommend security measures. Offers specialized knowledge on security practices, helps identify potential threats and vulnerabilities. clarify the scope and objectives.

Legal team: Ensures that the project's objectives and scope align with legal obligations. provides an overview of relevant laws, regulations, and standards that impact information security and data protection. This includes laws such as GDPR (General Data Protection Regulation) and other industry-specific regulations. outlines the legal obligations of the organization regarding data security, breach notification, consent requirements, and other relevant legal aspects.

Workshop 2: Context Definition

Stakeholders:

CEO

CISO

Business Owner

IT Manager

Data Protection Officer (DPO)

Security Expert

Legal team

Roles and Responsibilities:

CEO: Review and approve the identified sources of risk and associated attack objectives. Ensure alignment between the identified risks and the organization's overall strategic goals.

CISO: Provide technical insights into potential sources of risk and their attack objectives. Offer guidance on relevant cyber threats and attack vectors that could exploit identified vulnerabilities.

Business Owner: Provide insights into potential sources of risk that could impact business processes and operations. Collaborate with the team to identify potential attack objectives that could disrupt business activities.

IT Manager: Identify potential technical vulnerabilities and weaknesses in IT systems. Assist in defining potential attack scenarios and objectives that exploit IT vulnerabilities.

DPO: Identify potential sources of risk related to data breaches and privacy violations. Collaborate to identify attack objectives that target sensitive data and violate data protection regulations.

Security Expert: Offer insights into various security threats and potential attack objectives. Collaborate in identifying specific security risks and potential attack vectors.

Legal team: Review and verify that the identified sources of risk and potential attack objectives comply with relevant laws and regulations. Provide insights into the legal implications of specific risks and potential attacks.

Workshop 3: Strategic scenarios

Stakeholders:

CEO

CISO

Business Owner

IT Manager

Data Protection Officer (DPO)

Security Expert

Legal team

Roles and Responsibilities:

CEO: Contribute insights into strategic business goals and potential scenarios that could impact the organization. Review and provide input on identified

strategic scenarios from a business perspective. Ensure alignment between the identified scenarios and the organization's overarching strategic objectives.

CISO: Provide insights into potential security-related strategic scenarios, such as emerging threats or vulnerabilities. Identify scenarios related to evolving cybersecurity trends and potential impacts on the organization. Offer guidance on how to mitigate or manage security risks associated with the identified scenarios.

Business Owner: Contribute insights into potential strategic scenarios that could affect business operations or objectives. Identify scenarios related to market changes, competitive pressures, or shifts in customer behavior. Help prioritize strategic scenarios based on their potential impact on the business.

IT Manager: Identify scenarios related to technological advancements, changes in IT infrastructure, or potential system vulnerabilities. Assess the potential impact of identified scenarios on the organization's IT environment. Offer insights into how the organization's technical capabilities may need to evolve to address strategic scenarios.

DPO: Identify scenarios related to data breaches, data privacy violations, or regulatory changes. Assess the potential impact of strategic scenarios on data protection obligations and compliance. Offer recommendations on how to ensure data privacy and protection in the face of identified scenarios.

Security Expert: Identify scenarios related to potential security breaches, cyberattacks, or security policy changes. Assess the potential impact of security-related scenarios on the organization's overall security posture. Offer guidance on security measures and controls that could address the identified scenarios.

Legal team: Identify scenarios related to legal and regulatory changes that could impact the organization. Assess the potential legal implications of identified strategic scenarios. Offer guidance on how to ensure compliance with relevant laws and regulations in response to the scenarios.

Workshop 4: Operational scenarios

Stakeholders:

CEO

CISO

Business Owner

IT Manager

Data Protection Officer (DPO)

Security Expert

Legal team

Roles and Responsibilities:

CEO: Review and ensure that the identified operational scenarios align with the organization's strategic goals.

CISO: Provide insights into potential security risks and vulnerabilities related to the identified operational scenarios. Offer guidance on the relevance of each operational scenario from a security perspective. Ensure that the identified scenarios are comprehensive and adequately cover potential security concerns.

Business Owner: Lead discussions on different business processes and activities to help identify relevant operational scenarios. Ensure that the identified scenarios align with the organization's core business functions.

IT Manager: Provide technical expertise on the organization's IT infrastructure and systems. Assist in identifying operational scenarios that involve IT systems, networks, and technology. Offer insights into the potential technical challenges associated with each operational scenario.

DPO: Ensure that potential data privacy risks and implications are considered for each operational scenario. Offer guidance on scenarios that involve personal data and potential regulatory concerns.

Security Expert: Offer insights into the security implications of different operational scenarios. Identify potential threats and vulnerabilities that may arise in each scenario.

Legal team: Provide insights into legal and regulatory requirements that may impact the identified scenarios. Offer guidance on potential legal implications and considerations for each operational scenario. Ensure that the identified scenarios align with relevant laws and regulations.

Workshop 5: Risk Mitigation

Stakeholders:

CEO

CISO

Business Owner

IT Manager

Data Protection Officer (DPO)

Security Expert

Legal team

Roles and Responsibilities:

CEO: Review and approve the final risk treatment plan and associated security measures. Ensure that the chosen security measures align with the organization's strategic objectives and risk management strategy.

CISO: Provide detailed insights into the technical aspects of the selected security measures for risk mitigation. Ensure that the proposed security controls effectively mitigate the identified risks. Collaborate with other stakeholders to refine and optimize the risk treatment plan.

Business Owner: Participate in the finalization of the risk treatment plan and the selection of specific security measures. Provide insights into the operational and financial implications of the chosen risk mitigation actions. Ensure that the selected security measures align with the organization's business processes and objectives.

IT Manager: Review and validate the technical feasibility and implementation aspects of the selected security measures. Ensure that the chosen security controls are implementable within the organization's IT infrastructure.

DPO: Verify that the selected security measures adequately address data protection and privacy concerns. Ensure that the proposed risk mitigation actions align with relevant data protection regulations.

Security Expert: Provide detailed insights into the technical and operational aspects of the selected security measures for risk mitigation. Ensure that the proposed security controls are appropriate and effective in mitigating identified risks. Collaborate with other stakeholders to optimize and refine the risk treatment plan.

Legal team: Review and verify that the selected security measures comply with relevant laws and regulations. Ensure that the proposed risk mitigation actions do not conflict with any legal requirements.

Define the business and technical scope:

The scope includes the e-commerce website, customer database, payment processing system, and associated IT infrastructure. The technical scope includes security measures addressing vulnerabilities in the website, database, payment gateway, network, and internal systems, ensuring compliance with data protection regulations and industry standards:

Business Scope	Technical Scope
E-commerce website management	Web server, Content Management System (CMS), database server, Network infrastructure, load balancers
Customer data management and storage	Customer database, data storage infrastructure
Payment processing and transaction handling	transaction processing systems
User authentication and account management	User authentication systems, account management systems

Identify feared events

Step 1: Identify Assets and Threats

Identify the assets (what needs protection) and the threats (potential risks) to those assets.

Assets:

- E-commerce website
- Customer data (names, addresses, payment details)
- Payment processing infrastructure
- Company reputation

Threats:

- Cyberattacks (e.g., hacking, malware)
- Data breaches (unauthorized access to customer data)
- Payment fraud
- Service disruption (website downtime)
- Regulatory non-compliance (data protection regulations)

Step 2: Define Feared Events

For each threat, identify potential feared events or adverse scenarios that could result from these threats.

Feared Events:

Cyberattack on the E-commerce Website:

- Feared Event: Unauthorized access to the website's admin panel, leading to defacement or disruption of the site.

Data Breach of Customer Information:

- Feared Event: Theft of customer data, including names, addresses, and payment details, leading to potential identity theft and financial loss for customers.

Payment Fraud:

- Feared Event: Unauthorized use of stolen payment information to make fraudulent transactions, resulting in financial losses for both customers and the company.

Service Disruption:

- Feared Event: DDoS attack on the website, causing prolonged downtime and preventing customers from accessing the platform.

Regulatory Non-Compliance:

- Feared Event: Violation of data protection regulations (e.g., GDPR) due to improper handling of customer data, resulting in legal penalties and reputational damage.

Step 3: Prioritize Feared Events

Rank the identified feared events based on their potential impact severity.

Priority Order:

Feared event	Severitry
Regulatory Non-Compliance	G4
Payment Fraud	G4
Cyberattack on the E-commerce Website	G4
Data Breach of Customer Information	G4
Service Disruption	G3

Security baseline

Clause	Conformity	Explanation
A.5 Information Security Policies	Implemented	The e-commerce company has established information security policies that guide the organization's approach to managing information security. These policies are regularly reviewed and updated to align with changing business needs and security requirements.
A.6 Organization of Information Security	Partial	While the organization has defined roles and responsibilities for information security management, there is a need to further formalize the structure of the information security management function
A.7 Human Resource Security	Partial	The organization has basic security awareness training in place for employees. However, there is room for improvement in terms of providing role-specific training, conducting background checks, and ensuring that employees are fully aware of their information security responsibilities
A.8 Asset Management	implemented	The e-commerce company maintains an inventory of critical assets, including the e-commerce website, customer data, and payment processing system. Assets are classified based on their importance, and appropriate controls are in place to protect these assets.
A.9 Access Control	Partial	While access controls are implemented, there is room for improvement in terms of enforcing the principle of least privilege and implementing multi-factor authentication for sensitive systems and data access.
A.10 Cryptography	Implemented	The organization applies encryption to protect sensitive data, including customer payment information, both in transit and at rest. Secure key management practices are in place to ensure the confidentiality and integrity of cryptographic keys
A.11 Physical and Environmental Security	Implemented	The e-commerce company implements physical and environmental security measures to protect its facilities and critical assets, including access controls, surveillance, and environmental controls for data centers.
A.12 Operations Security	Partial	While operational procedures are in place, there is a need for formal incident response and business continuity plans to effectively manage security incidents and disruptions.

A.13 Communications Security	Implemented	The organization implements secure communication measures to protect the confidentiality and integrity of data during transmission, including encryption and secure network configurations.
A.14 System Acquisition, Development, and Maintenance	Partial	While there are development and maintenance processes, there is a need to formalize secure coding practices and conduct regular security assessments to identify and address vulnerabilities in software and systems.
A.15 Supplier Relationships	Implemented	The e-commerce company has established security requirements for third-party vendors and partners and regularly assesses their compliance with these requirements.
A.16 Information Security Incident Management	Partial	While there are incident management processes, there is a need to further enhance the incident response plan to ensure effective handling of security incidents, including data breaches and cyberattacks.
A.17 Information Security Aspects of Business Continuity Management	Implemented	The organization has established business continuity and disaster recovery plans to ensure the organization's ability to recover from disruptions, including service outages and data breaches.
A.18 Compliance	Partial	While the organization is aware of relevant regulations, there is a need for a more structured approach to ensure ongoing compliance with data protection regulations, such as GDPR. Overall, while the e-commerce company demonstrates a level of conformity to ISO 27001 Annex A controls, there are areas where improvements can be made to enhance the effectiveness and comprehensiveness of the information security management system. The organization should focus on addressing the identified gaps and further strengthening its information security practices ensuring a robust and holistic approach to protecting its assets, operations, and customer data.

VI. Practical exercise 3

Exercise :

You are an IT security specialist at a large bank that offers online banking services to its customers. Your task is to identify the scope of activities and assets that will be included in the risk assessment for the bank's online banking system, using the EBIOS Risk Management methodology.

Solution :

Collect documentation related to the bank's online banking system. This includes system architecture diagrams, process flows for online transactions, asset inventories. Identify points where sensitive data is transmitted, processed, and stored.

Identify the processes and information within the online banking system.

List the critical assets associated with the online banking system. These assets may include :

- account management
- funds transfers
- bill payments
- customer accounts
- financial transaction data
- authentication mechanisms
- servers Hosting Online Banking Services
- databases Storing Customer and Transaction Data
- Network Infrastructure (Firewalls, Routers, Switches)

VII. Practical exercise 4

Exercise :

You are an IT security analyst working for a manufacturing company that uses an enterprise resource planning (ERP) system to manage its operations, including inventory, production, and order processing. Your task is to identify and define feared events associated with potential risks to the ERP system using the EBIOS Risk Management methodology.

Solution :

Feared Event 1: Unauthorized Access to Sensitive Data

- Description: A malicious actor gains unauthorized access to the ERP system and extracts sensitive production data and customer information.
- Impact: Compromised customer data, potential legal consequences, reputational damage, operational disruption, and financial losses due to legal fees and customer compensation (severity = high)

Feared Event 2: Server Downtime or Outage

- Description: The primary database server experiences unexpected downtime, rendering the ERP system unavailable.
- Impact: Halting critical activities like order processing and production scheduling, delayed shipments, loss of customer satisfaction, operational and financial losses (severity = high)

Feared Event 3: Data Corruption or Loss

- Description: Critical production data becomes corrupted or is unintentionally deleted, leading to inaccurate production planning and decision-making.
- Impact: Production disruptions, incorrect inventory management, financial losses due to inefficient operations, customer dissatisfaction (severity = high)

Feared Event 4: Insider Threats (Malicious Employees)

- Description: An employee with malicious intent deliberately manipulates production data or introduces vulnerabilities into the ERP system.
- Impact: Compromised data integrity, operational disruptions, potential loss of proprietary information, reputational damage, financial losses due to system recovery and investigations (severity = high)

Feared Event 5: System Misconfiguration

- Description: Configuration errors in the ERP system lead to unintended vulnerabilities, potentially exploited by attackers.
- Impact: Unauthorized access, data breaches, potential financial losses due to legal fees, customer compensation, and operational disruptions (severity = medium)

IIX-Workshop II (Risk Origins)

The main objectives of Workshop 2 are:

- **Identify sources of risks:** This involves identifying all potential sources of risks that could impact the assets within the studied scope.
- **Define objectives of risk sources:** For each identified risk source, it's essential to clearly define the objectives of that source, which means understanding the motivations or intentions that could lead to the exploitation of vulnerabilities.

Workshop 2 Process:

- **Presentation of Context:** Organizers introduce the project context and reiterate the overall goals of risk analysis. They explain that the workshop will focus on identifying sources of risks and defining their objectives.
- **Information Collection:** Stakeholders are encouraged to share their knowledge and expertise in order to identify potential sources of risks. These sources can be related to internal and external actors, events, etc.
- **List of Risk Sources:** Participants compile a comprehensive list of identified risk sources. These sources may include both internal and external threats, and more.
- **Defining Objectives of Risk Sources:** For each identified risk source, participants define the specific objectives associated with those sources. They attempt to understand the reasons why these sources might exploit vulnerability.
- **Analysis and Documentation:** The collected information is thoroughly analyzed and documented. Each risk source is described in detail, along with its specific objectives. This documentation will serve as the basis for further risk analysis.

Workshop 2 Results:

At the end of Workshop 2, the results include:

- A comprehensive list of identified risk sources within the studied scope.
- A detailed description of the objectives associated with each risk source.
- A better understanding of the potential motivations and intentions behind each risk source.

1. Identify the risk origins and the target objectives

a. Identify the risk origins

- **Nation-State and State-Sponsored Groups:**

Individuals or groups that are sponsored, directed, or otherwise supported by a national government. These actors often possess significant resources, including technical expertise, funding, and advanced tools, enabling them to conduct sophisticated and prolonged cyber espionage, cyber attacks, or other malicious activities. These groups may have affiliations with governmental organizations, intelligence agencies, or military units.

Example:

APT28 (Fancy Bear): A Russian nation-state group known for conducting cyber espionage. They are associated with numerous high-profile attacks, including the 2016 Democratic National Committee (DNC) breach, which targeted the U.S. election.

APT29 (Cozy Bear): Another Russian group known for cyber espionage. They have targeted governments, military organizations, and research institutions. APT29 was implicated in the breach of the U.S. Office of Personnel Management (OPM) in 2015.

APT41: This Chinese nation-state group has been linked to both cyber espionage and financially motivated cybercrime. They have targeted a wide range of sectors, including technology, healthcare, and gaming.

Lazarus Group: Associated with North Korea, Lazarus Group is known for conducting cyber espionage, financial theft, and disruptive attacks. They were linked to the 2014 Sony Pictures hack.

Charming Kitten: A state-sponsored Iranian group that conducts spear phishing campaigns against political targets, journalists, and dissidents.

- **Criminal Organizations**

Criminal organizations refer to groups or entities that engage in cybercriminal activities for financial gain, without necessarily having direct ties to a nation-state or government. These organizations are primarily motivated by profit and typically operate with the intent of committing various types of cybercrimes.

Examples:

Carbanak Group (FIN7): known as FIN7, targeted financial institutions, retailers, and hospitality industries. They stole payment card data through sophisticated phishing campaigns and card-skimming malware.

DarkTequila: It used malware to steal sensitive information such as banking credentials, personal documents, and other valuable data.

Lazarus Group: engaged in cyberattacks for both political and financial gain. They are known for the 2014 Sony Pictures hack and various financially motivated attacks, including cryptocurrency theft.

Magecart Group: compromise e-commerce websites to inject malicious code that steals payment card data from customers making online purchases.

REvil (Sodinokibi): operates a ransomware-as-a-service model, leasing their ransomware to affiliates who then carry out attacks. They've been involved in high-profile attacks, including targeting managed service providers (MSPs) to reach multiple victims.

- **Hacktivists**

Refer to individuals or groups that engage in hacking activities to advance a social or political cause. Unlike criminal organizations or nation-state actors, hacktivists are primarily motivated by ideological or ethical reasons rather than financial gain or governmental objectives.

Examples:

Anonymous: is an organized hacktivist collective that has engaged in various activities to support their causes. They have conducted DDoS attacks against websites, defaced web pages, and exposed sensitive information through data leaks. They've targeted government institutions, corporations, and organizations they view as oppressive or unethical.

RedHack: is a Turkish hacktivist group known for its involvement in political issues. They have defaced government websites, leaked sensitive government emails, and disclosed information related to political corruption.

AntiSec (LulzSec): engaged in hacking activities to expose perceived corruption and privacy violations. They breached various websites, leaked user data, and targeted government agencies.

- **Ransomware operators**

refer to individuals or groups that develop, deploy, and manage ransomware attacks. Ransomware is a type of malicious software that encrypts a victim's data or locks them out of their systems until a ransom is paid, typically in cryptocurrency. Ransomware operators aim to extort money from victims by holding their data hostage.

- **Cyber espionage actor**

refers to an individual or group that engages in cyber espionage activities, which involve the unauthorized acquisition of sensitive or classified information from individuals, organizations, or governments for intelligence or strategic purposes.

- **Cyber terrorist**

Refers to an individual or group that employs cyber attacks as a means to advance ideological, political, or religious goals by causing fear, disruption, and harm. Cyber terrorists use digital means to target critical infrastructure, organizations, governments, or individuals with the intention of achieving their objectives through acts of cyber terrorism.

- **Insider**

Refers to an individual who has authorized access to an organization's systems, networks, or data and uses that access to compromise the confidentiality, integrity, or availability of information or assets. Unlike external attackers, insiders already have a level of trust and legitimate access within the organization.

- **Amateur**

Refers to an individual or group with limited or basic hacking skills and resources. Amateurs have relatively low levels of expertise compared to more advanced threat actors like professional cybercriminals, nation-state actors, or skilled hacktivists. They might lack in-depth knowledge of sophisticated attack techniques and tools.

- **Competitors**

Refer to other organizations or entities operating within the same industry or market as the target organization. Competitors might engage in various activities, including information gathering or corporate espionage, to gain a competitive advantage.

- **Cybercriminals**

engage in various types of cybercrime for financial gain. Financial profit is the primary motivation for cybercriminals. They might engage in activities like ransomware attacks, phishing, identity theft, and selling stolen data.

- b. Identify the target objectives

- **Financial Gain**

- ° Stealing financial information (credit card numbers, bank accounts, ...).
- ° Extorting money through ransomware or other attacks.

- **Espionage**

- ° Stealing sensitive corporate or personal data for competitive advantage.
- ° Gathering intelligence on government entities, corporations, or individuals.
- ° Intellectual property theft for economic gain or technological advancement.

- **Disruption**

- ° Disrupting critical infrastructure (power grids, transportation systems, ...).
- ° Destroying or altering data to cause operational chaos.
- ° Disrupting online services and websites.

- **Identity Theft**

- ° Stealing personal information to impersonate individuals.
- ° Creating fake identities for various malicious purposes.

- **Extorting money**

From individuals or organizations by encrypting their data and demanding payment for its release.

- **Undermining Competitors**

Target competing businesses to gain a competitive advantage by stealing their intellectual property or disrupting their operations.

- **Building Botnets**

Infect devices with malware to build botnets, which can be used for various purposes, such as sending spam emails or launching further cyberattacks.

- **Phishing**

- Tricking individuals into revealing sensitive information.

- Manipulating people to click on malicious links or download malware.

- **Harassment**

- Targeting individuals with the intent to harm, intimidate, or defame.

- Posting personal or sensitive information to cause emotional distress.

- **Disrupting**

- Overwhelming a target's servers to make services unavailable.

- Causing downtime and disrupting online operations.

- **Political Influence**

Influence foreign elections, policies, or public opinions by conducting cyber operations that manipulate information or spread disinformation.

- **Cyber Deterrence**

Develop offensive cyber capabilities as a deterrent against adversaries, signaling their ability to respond with cyber attacks if provoked.

- **Gathering Intelligence**

State-sponsored groups might collect information on foreign governments, organizations, or individuals to support national security and foreign policy objectives.

- **Global Impact**

Using the internet as a platform to raise awareness and drive change across borders. These actions can have significant impacts that reach far beyond the local region.

- **Pressure for Change**

By disrupting services, leaking sensitive information, or defacing websites to put pressure on targeted entities to change their policies, actions, or behaviors according to some demands.

- **Supporting Political Movements**

Use cyber-attacks to support movements. This can involve disrupting websites, leaking confidential information, or spreading propaganda that aligns with the movement's objectives.

- **Protesting**

Target organizations, government agencies, or institutions that they perceive as engaging in unethical or oppressive activities. The goal is to publicly voice opposition and draw attention to the issue of advocating for.

- **Ransom Payment**

Compel victims to pay a ransom to obtain the decryption key. The ransom payment is often demanded in cryptocurrencies like Bitcoin to make it difficult to trace.

- **Economic Disruption**

Disrupt the victim's operations and cause economic losses. Organizations may be forced to temporarily halt operations or pay significant amounts to regain access to their systems.

- **Economic Advantage**

Gathering information about competitors' strategies, product plans, market research, and financial data can provide an economic advantage. This stolen information might be used to anticipate market trends or to design products and services more effectively.

- **Intellectual Property Theft**

Target industries and organizations to steal valuable intellectual property, such as proprietary technology, research data, designs, formulas, and trade secrets. This stolen information can provide a significant advantage to competitors or foreign entities.

- **Instilling Fear**

Seek to create fear and panic among the targeted population or audience. By conducting high-profile cyberattacks that disrupt critical infrastructure or cause significant damage, that aim to generate anxiety and insecurity.

- **Promoting Ideology**

Promote or impose specific ideological, political, or religious beliefs. Use cyberattacks to undermine opposing ideologies, spread propaganda.

- **Gaining Recognition**

Gain attention on a global scale. Carrying out impactful and well-publicized cyberattacks to draw the attention of the media, governments, and the public to their cause.

- **Disrupting Normal Operations**

Aim to disrupt normal operations, particularly within critical infrastructure sectors such as energy, finance, healthcare, and transportation. This disruption can lead to economic losses, inconvenience, and potential harm to individuals.

- **Undermining Trust**

Target systems and networks that people rely on for communication, information sharing, and everyday activities. By compromising these systems, attackers aim to undermine trust in digital infrastructure and institutions.

- **Influencing Political Decisions**

Attempt to influence political decisions or policies by targeting government agencies, political parties, or influential individuals. They may release sensitive information to shape public opinion or create chaos within political systems.

- **Curiosity and Exploration**

Explore and learn about the world of cybersecurity, computer systems, and networks. Carry out basic attacks to understand how different techniques work.

- **Personal Challenge**

Attackers engage in hacking as a personal challenge or to prove their abilities to themselves or their peers. The objective here is often to showcase their achievements within their social circles.

- **Attention-Seeking**

Some individuals may seek attention or recognition within online communities by demonstrating their hacking skills. This could involve sharing their exploits, hacks, or defacements on public forums.

- **Learning and Experimentation**

Attackers view their actions as a way to learn and experiment with various hacking techniques. They might attempt to understand vulnerabilities, exploits, and the workings of different tools.

2. Identify the pairs (Risk origin/Target objectives)

Identifying the target objectives for each risk origin is crucial for conducting a comprehensive and effective risk assessment. This step helps to clarify the motivations and intentions behind potential threats, which is essential for evaluating the impact, likelihood, and severity of risks.

By determining the objectives of each risk origin, you gain insights into why they might target the assets within your scope. This understanding is vital for evaluating the potential impact of an attack, as different objectives can lead to varying levels of harm.

Some risk origins may seek financial gain, while others might be motivated by causing disruption, stealing sensitive information, or tarnishing an organization's reputation. Knowing these objectives helps assess the potential impact of a successful attack.

Identifying the target objectives can also help in estimating the likelihood of an attack. If a risk origin's objectives align with your assets and their potential vulnerabilities, it increases the likelihood that they might attempt an attack.

Not all risk origins pose equal threats. By understanding their objectives, you can prioritize risks based on their potential impact, the likelihood of attack, and the alignment of objectives with your organization's context.

When you can clearly articulate the objectives of potential threat actors, it's easier to communicate the potential risks to stakeholders, allowing for a more informed decision-making process.

Risk origins	Target objectives
Nation-State and State-Sponsored Groups	◦ Espionage ◦ Political Influence ◦ Cyber Deterrence ◦ Gathering Intelligence
Criminal Organizations	◦ Financial Gain ◦ Identity Theft ◦ Extorting money ◦ Undermining Competitors ◦ Building Botnets
Hacktivist	◦ Global Impact ◦ Pressure for Change ◦ Supporting Political Movements ◦ Protesting
Ransomware operators	◦ Ransom Payment ◦ Economic Disruption ◦ Financial Gain
Cyber espionage actor	◦ Economic Advantage ◦ Intellectual Property Theft
Cyber terrorist	◦ Instilling Fear ◦ Gaining Recognition ◦ Disrupting Normal Operations ◦ Undermining Trust ◦ Influencing Political Decisions
Insider	◦ Sabotage ◦ Espionage ◦ Theft sensitive data
Amateur	◦ Curiosity and Exploration ◦ Personal Challenge ◦ Attention-Seeking

3. Assessing the pairs (Risk origin/Target objectives)

Assessing each pair of Risk Origin and Target Objectives is a crucial step in understanding the potential risks that an organization faces. This assessment helps identify potential impacts, and the context in which these risks could materialize.

Assessing each pair helps in understanding the various sources or actors (Risk Origins) that could pose threats to an organization and the specific objectives (Target Objectives) they might aim to achieve. This understanding enables organizations to anticipate potential attack vectors and tactics used by these threat actors.

By assessing the Risk Origin and Target Objectives, organizations can identify vulnerabilities in their systems, processes, or assets that could be exploited by malicious actors. This evaluation helps in identifying weak points that need strengthening to prevent potential attacks.

Understanding the motives and objectives of potential threat actors allows organizations to tailor their security measures to counter the specific risks associated with each pair. Different threat actors might have varying techniques, which require specialized security strategies for effective defense.

By assessing each pair, organizations can prioritize risks based on the potential impact and likelihood of occurrence. Some risk origins and target objectives might pose more significant threats than others, and this prioritization helps allocate resources effectively to address the most critical risks first.

Motivation

- Low Motivation

In low-motivation cyber-attacks, the attackers are driven by relatively simple and unsophisticated reasons. Their actions may be impulsive, opportunistic, or without clear strategic intent. The potential impacts of their attacks are limited and may not have a significant overall effect.

Examples

- Random Acts: Unplanned, spontaneous attacks carried out without a clear objective or long-term intention.
- Pranks: Hacking activities intended to cause amusement or minor disruptions without causing lasting harm.
- Curiosity: Exploring systems or networks without malicious intent, driven by a desire to learn or experiment.

- **Significant Motivation**

In significant-motivation cyber-attacks, the attackers have specific objectives in mind and plan their actions with a higher degree of purpose. These attackers are more determined and skilled, and their actions can lead to tangible outcomes such as financial gain, data theft, or reputational damage.

Examples

- Financial Gain: Attacks with the goal of generating profits through means such as ransomware, financial fraud, or identity theft.
- Data Breaches: Targeting systems to steal valuable data, personal information, or intellectual property for resale or exploitation.
- Hacktivism: Carrying out attacks to raise awareness, promote a cause, or disrupt organizations or systems aligned with opposing ideologies.

- **High Motivation**

In high-motivation cyber-attacks, the attackers are driven by sophisticated motives, strategic objectives, or involvement in complex and organized activities. These attackers possess advanced skills and resources, and their actions can have significant implications, potentially affecting national security, critical infrastructure, or global stability.

Examples

- Nation-State Actors: Coordinated cyber operations by governments targeting rival nations for political, economic, or strategic advantages.
- Espionage: Infiltrating systems to gather intelligence, trade secrets, or sensitive information for governmental, economic, or military purposes.
- Cyber Warfare: Engaging in large-scale, strategic cyber-attacks with the potential to disrupt critical infrastructure or even initiate conflicts.

Ressources

- Low Resources:

In cyber-attacks with low resources, attackers have limited capabilities, tools, and expertise at their disposal. These attackers might primarily rely on easily available, open-source hacking tools and have a basic understanding of hacking techniques. Their attacks may be relatively unsophisticated and opportunistic.

Example

- Limited Technical Knowledge: Attackers at this level might have basic understanding of hacking concepts but lack deep technical expertise.
- Simple Tools: They use readily available hacking tools, often without customization or advanced features.
- Targets of Opportunity: Low-resource attackers often go after easy targets with known vulnerabilities.

- Significant Resources

In cyber-attacks with significant resources, attackers have more advanced tools, knowledge, and capabilities. These attackers are more strategic in their approach and may be capable of carrying out targeted attacks on specific organizations or systems. They invest more effort into their attacks and can potentially cause more damage.

Examples

- Intermediate Technical Knowledge: Attackers at this level possess a higher level of technical expertise and can develop or modify hacking tools as needed.
- Customized Tools: They may create or customize tools to suit their specific attack objectives, making their attacks more effective.
- Targeted Attacks: Significant-resource attackers can identify and exploit vulnerabilities specific to their chosen targets.

- High Resources

In cyber-attacks with high resources, attackers have substantial capabilities, including advanced technical expertise, access to sophisticated tools, and potentially even state-sponsored backing. These attackers are highly skilled and well-funded, often pursuing complex and strategic objectives.

Examples

- Advanced Technical Knowledge: Attackers at this level have advanced knowledge of hacking techniques, often including cutting-edge skills in various domains.
- Sophisticated Tools: They use advanced and often proprietary tools and techniques, which may include zero-day exploits and custom malware.
- Complex Campaigns: High-resource attackers can carry out complex, multi-stage attacks with precise execution.

Matrix of evaluation (Motivation/Resources)

	Resources			
		Low	Significant	High
Motivation	High	Medium	High	High
	Significant	Low	Medium	High
	Low	Low	Low	Medium

Risk origins	Target objectives	Motivation	Resources	
Nation-State	Gathering Intelligence	High	High	High
Criminal Organizations	Financial Gain	High	Significant	High
Hacktivist	Pressure for Change	High	Low	Medium
Ransomware operators	Ransom Payment	High	Significant	High
Cyber espionage actor	Economic Advantage	Significant	Significant	Medium
Cyber terrorist	Influencing Political Decisions	High	Low	Medium
Insider	Sabotage	Significant	Low	Low
Amateur	Curiosity and Exploration	Low	Low	Low

4. Selecting the pairs (Risk origin/Target objectives)

Selecting pairs of Risk Origins and Target Objectives based on the severity of the levels. We will choose as example, medium and high levels. These pairs represent scenarios where attackers possess significant technical capabilities and potentially well-funded resources.

Risk origins	Target objectives	Motivation	Resources	
Nation-State	Gathering Intelligence	High	High	High
Criminal Organizations	Financial Gain	High	Significant	High
Hackivist	Pressure for Change	High	Low	Medium
Ransomware operators	Ransom Payment	High	Significant	High
Cyber espionage actor	Economic Advantage	Significant	Significant	Medium
Cyber terrorist	Influencing Political Decisions	High	Low	Medium

5. Linking the pairs (Risk origin/Target objectives) with Feared events

Linking the pairs of **Risk Origin** and **Target Objectives** with the corresponding **Feared Event** is a crucial step that enhances the risk assessment process. Feared Events represent potential negative outcomes or consequences that could result from the exploitation of a vulnerability by a specific attacker with a particular objective and a particular resource.

Risk origins	Target objectives	Motivation	Resources	
Nation-State	Gathering Intelligence	High	High	High
Criminal Organizations	Financial Gain	High	Significant	High
Hacktivist	Pressure for Change	High	Low	Medium
Ransomware operators	Ransom Payment	High	Significant	High
Cyber espionage actor	Economic Advantage	Significant	Significant	Medium
Cyber terrorist	Influencing Political Decisions	High	Low	Medium

Scenario	Business asset	Feared event	severity
A ransomware attack (feared event) compromises sensitive data (business asset) resulting in reputational damage	sensitive data	ransomware attack	G4
Malware infection spreading across internal network (feared event) impacts confidential documents (business asset)	Malware infection	confidential documents	G4
Theft of company laptops (feared event) lead to disclosure of sensitive data (business asset) stored on them	sensitive data	Theft of company laptops	G4
A data breach (feared event) exposes credit card information (business asset)	credit card information	data breach	G4
Malicious modification (feared event) alters critical files (business asset)	critical files	Malicious modification	G4
Business Continuity Impact: The interruption to an organization's ability to continue its business functions	A business process	interruption	G4
An external hacktivist group successfully defaced the company website temporarily	Web site management	Defacement web site	G2
A minor malware infection affected a non-critical system due to a user's inadvertent download of a malicious file, causing only isolated disruption and minimal data loss	Non-critical system	Malware infection	G1

IX-Practical Exercise 5

Exercise:

You are part of a cybersecurity team at a bank. Your task is to identify potential risk origins that could pose threats to the bank's security and operations. Consider various attacker motivations and sources of potential attacks.

Bank Information:

The bank offers online banking services.

It holds sensitive customer financial information.

It handles transactions for retail and corporate clients.

It has a mobile banking application.

Solution:

- Organized Cybercrime Group:

Motivation: High

Resources: High

Potential Impact: High

Explanation: Organized cybercrime groups often target financial institutions to steal customer data, execute fraudulent transactions, or deploy ransomware. They can exploit vulnerabilities in the bank's online systems or mobile app to compromise customer accounts and conduct financial fraud.

- Insider Threat (Disgruntled Employee):

Motivation: Low

Resources: Significant

Potential Impact : Significant

Explanation: Disgruntled employees with insider access can misuse their privileges to access sensitive customer information, disrupt operations, or leak confidential data. They might exploit vulnerabilities in internal systems to carry out their activities.

- Hactivist Group:

Motivation: Low

Resources: Low

Potential Impact: Low

Explanation: Hactivist groups might target the bank to raise awareness about perceived financial injustices or unethical practices. While the potential for disruption exists, their focus is usually on high-profile targets rather than financial institutions.

- Hacker (Phishing):

Motivation: High

Resource: significant

Potential Impact: High

Explanation: Phishing attacks might unknowingly compromise their accounts. Attackers could use stolen credentials to gain unauthorized access to online banking or the mobile app.

X-Practical Exercise 6

Exercise:

You are a cybersecurity analyst working for a manufacturing company that specializes in producing industrial machinery. Your task is to identify potential risk origins that could pose threats to the company's security, operations, and the safety of its employees. Consider various attacker motivations and sources of potential attacks.

Company Information:

The manufacturing company produces large-scale industrial machinery used in various industries.

The company has a networked production environment that connects machines and control systems.

The company operates critical manufacturing processes that need to be operational at all times.

Employee safety and preventing accidents are top priorities.

Solution:

- Competitor Industrial Espionage:

Motivation: significant

Resource: significant

Potential Impact: High

Explanation: Competitor organizations might attempt to steal the company's proprietary manufacturing processes, designs, or technical data. This could lead to intellectual property theft, loss of competitive advantage, and potential safety risks if competitors use the stolen information to create subpar machinery.

- Insider Threat (Sabotage):

Motivation: Medium

Resources: High

Potential Impact: High

Explanation: An insider with malicious intent might sabotage production processes by tampering with control systems. This could result in defective machinery, safety hazards, production downtime, and financial losses.

- Criminal Group (Ransomware):

Motivation: Low

Resources: significant

Potential Impact: Medium

Explanation: Criminal groups might deploy ransomware to extort the company by encrypting critical production systems. This could lead to disruptions in manufacturing processes, production delays, and potential safety concerns if essential equipment is affected.

XI-Workshop III (Strategic Scenarios)

1. Select the critical stakeholders

Prioritize stakeholders who, if compromised, could pose significant risks to the confidentiality, integrity, and availability of the system. Selecting critical stakeholders within a predefined scope based on these factors :

- Dependency
 - Identify stakeholders who have a high dependency on the information system or whose operations are heavily intertwined with the system in question.
 - Consider stakeholders whose services, products, or processes rely on the smooth functioning and security of the system.
- Penetration
 - Evaluate the stakeholders' potential to penetrate the system.
- Cyber maturity
 - Assess the cybersecurity maturity of stakeholders. This involves considering their level of preparedness, security policies, practices, and the effectiveness of their security controls.
- Trust
 - Consider the level of trust you have in each stakeholder. This can be based on historical interactions, track record, and the perceived reliability of the stakeholder.

The goal is essentially identifying key players who can significantly be impacted by the information system's security, and impact the system.

Rating grid :

	Dependency	Penetration	Cyber Maturity	Trust
1	These stakeholders may not rely heavily on the system for their daily operations, and its functionality has a limited impact on their objectives Example :Partners with Independent Systems: Partners or collaborators who operate independently of your specific IT infrastructure	No access: Stakeholders at this level do not have direct access to the information system	Stakeholders at this level have limited or unclear capabilities to respond effectively to security incidents. There may be a lack of established processes or resources for incident response, making it uncertain	There is a lack of information or confidence in understanding the stakeholder's intentions. The organization may not have sufficient knowledge or data to evaluate the stakeholder's motivations, reliability, or alignment with organizational goals. There may be uncertainty or suspicion regarding the stakeholder's actions and intentions
2	Stakeholders operations may be influenced by the system, but they are not as critical as those with high dependence Example :Suppliers with Electronic Transactions: Suppliers involved in electronic transactions or automated supply chain processes that are influenced by the IT system	Stakeholders have administrative access to workstations, which can potentially impact local systems and data	Stakeholder has some defined IT rules or guidelines, but these may not be fully integrated into the broader organizational policies	There might be some understanding of the stakeholder's intentions, they are considered neutral. There is a need for more information or a clearer assessment to form a definitive judgment about the stakeholder's alignment with organizational objectives
3	Stakeholders with high dependence on the IT system are those whose operations, services, or functions are significantly reliant on the secure functioning of the system Example :Suppliers Chain Partners : Suppliers that use online portals or integrated systems for order processing, inventory management, and supply chain coordination	Stakeholders have administrative access to servers, which can significantly impact the broader IT infrastructure and data	Stakeholder has reached a higher level of maturity by applying global policies. This means that there are overarching policies in place that guide and govern information security practices	The organization has a good understanding of the stakeholder's intentions, and those intentions are perceived as positive. There is confidence that the stakeholder's actions and goals align well with the organization's interests. The organization has evidence or experience indicating a reliable and positive relationship with the stakeholder
4	Whose operations, services, or functions are deeply intertwined with and heavily reliant on the smooth and secure functioning of the system Example :Healthcare Research and Biotechnology: Organizations conducting critical medical research that depend on advanced IT systems for data analysis, simulations, and collaboration	Stakeholders have administrative access to critical security infrastructure, potentially compromising the overall security posture of the system	This represents the highest level of maturity, where not only are policies in place, but they are also effectively applied. Additionally, the stakeholder has an effective risk management process. This implies that he not only has well-defined policies but also actively monitors, assesses, and manages risks in a systematic and efficient manner	The organization has a comprehensive understanding of the stakeholder's intentions, and those intentions are not only positive but also fully compatible with the organization's goals and values. There is a high degree of confidence that the stakeholder is a trustworthy and supportive partner, and their actions contribute positively to the organization's success

Estimating the threat level of the stakeholders :

$$\text{Threat level} = \text{Dependency} * \text{Penetration} / \text{Cyber Maturity} * \text{Trust}$$

Acceptable level of the Threat :

Threat level	Value	Acceptability	Recommendation
Very high	> 6	Unacceptable	No interaction with stakeholders
High	< 4 <= 6	control	Audit & continuous improvement
Low	< 4	Acceptable	No recommendation

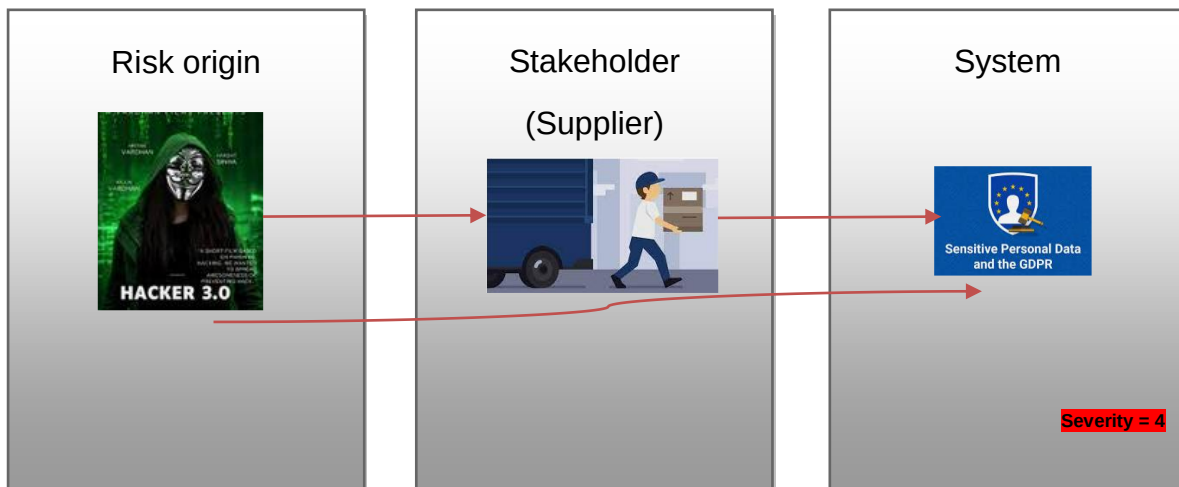
Example :

	stakeholder	Dependency	Penetration	Maturity	Trust	Level	estimation
Clients	C1 - Travellers	2	2	1	2	$2*2/1*2 = 2$	Low
	C2 - Subscribers	2	3	1	1	$2*3/1*1 = 6$	High
	C3 - cloud-based customer	3	3	1	1	$3*3/1*1 = 9$	Very high
Partners							
Suppliers							

2. Defining the Strategic scenarios

A strategic scenario, is a high-level scenario attacks that describe the sequences of feared events generated by the risk origin and could significantly affect the organization's strategic goals and information systems.

Example :



3. Defining the Security controls

For each strategic scenario, select controls that will effectively reduce the initial threat :

Stakeholder	Strategic scenario	Security control	Initial threat	Residual threat
Supplier	A ransomware attacker compromises sensitive data by breaking into the IT system of the supplier	Enforcing firewall filtering rules	3	2

XII-Practical Exercise 7

Exercise:

Context:

You are an IT security analyst working for a financial institution that provides online banking services. The organization has identified the need to assess risks related to its online banking platform.

Exercise Steps:

1. Risk Origin:

- o Identify a specific risk origin related to the online banking platform. Consider factors such as external threats, internal vulnerabilities, or changes in the technological landscape.

Example: External Threat : Phishing Attack

2. Objective of the Attack:

- o Define the objective that an attacker might have related to the identified risk origin. This should outline what the attacker aims to achieve through their actions.

Example: Objective : Obtain Login Credentials of Online Banking Users

3. Feared Event:

- o Determine the feared event that would result from the successful execution of the attack. This should describe the potential negative impact on the organization or its stakeholders.

Example: Feared Event : Unauthorized Access to Customer Accounts and Financial Data

4. Vulnerable Stakeholder:

- o Identify the vulnerable stakeholder who is affected by the attack and used to attack the banking system.

Example: internal Banking employee

5. Controls:

- o identify the controls to put in place to mitigate risks

Solution :

1. Risk Origin:

- Identified Risk Origin: Phishing Attacker
- Explanation: Phishing attacks involve tricking individuals into providing sensitive information, such as usernames and passwords, by posing as a trustworthy entity.

2. Objective of the Attack:

- Obtain Login Credentials of Online Banking Users
- Explanation: Attackers aim to deceive online banking users into revealing their login credentials through deceptive emails or fake websites to gain unauthorized access to their accounts

3. Feared Event:

- « Unauthorized Access to Customer Accounts and Financial Data »
- Explanation: If the phishing attack is successful, attacker could gain access to customers' online banking accounts, leading to potential financial loss, unauthorized transactions, and compromise of sensitive financial data.

4. Vulnerable Stakeholder:

- Identified Vulnerable Stakeholder: internal Banking employee
- Explanation: internal banking employee is vulnerable to phishing attacks as he may unknowingly fall victim to deceptive tactics, compromising the security of his login credentials and financial information.

5. Control

- Establish a process for continuous improvement and adaptation of controls based on emerging threats.
- Example: Regularly update phishing awareness materials and training content based on new tactics used by attackers.

XIII-Workshop IV (Operational Scenarios)

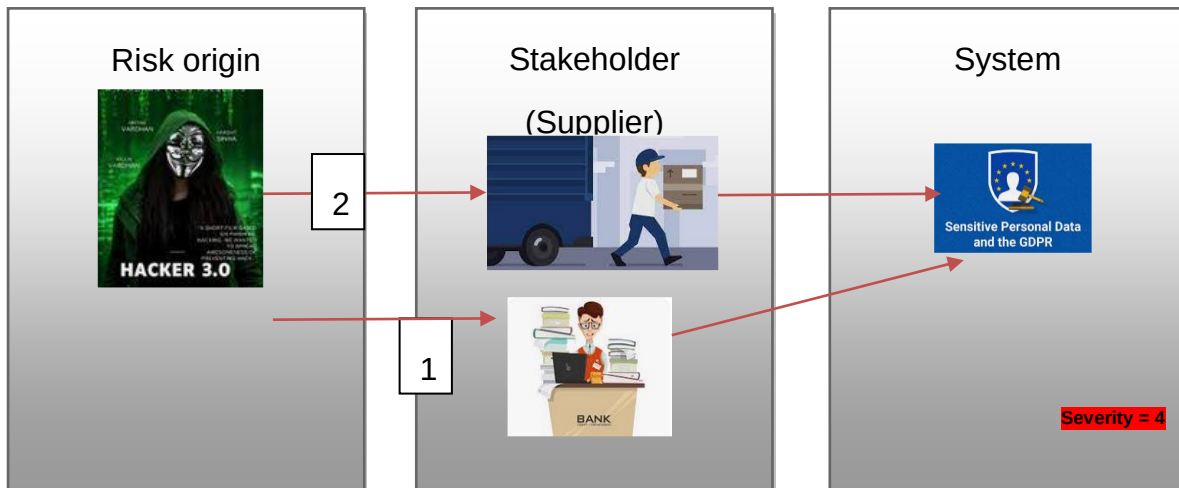
1. Develop the operational scenario

The operational scenario is a crucial component in understanding and managing risks to an information system. The methodology generally follows a systematic approach, and the operational scenario is a detailed representation of how a threat agent could exploit vulnerabilities to achieve a specific objective. For each attack path Select, determine through which supporting assets can the attacker achieve its targeted objective. These assets could be servers, databases, user accounts, or any other components within the system.

Analyze the attack path step by step. Consider the vulnerabilities associated with each supporting asset and how an attacker might exploit them. Evaluate the likelihood of successful exploitation.

Example :

Chose the path 1 of the folowing strategic scenario :



The attack is based on the Cyber Kill Chain model which is a concept used in the field of cybersecurity to describe the stages of a cyberattack. This model is used as a framework to understand and counteract cyber threats. The stages of the Cyber Kill Chain are summarized as follows:

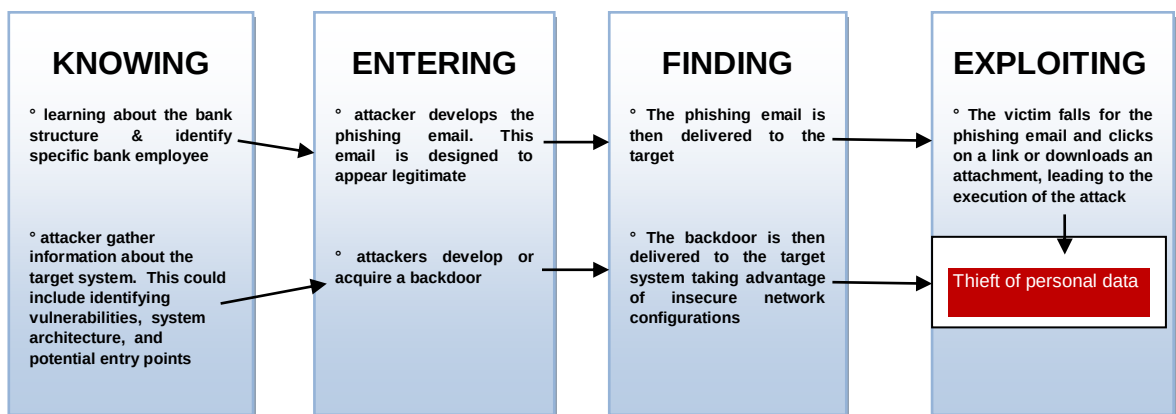
Knowing: In this stage, attackers gather information about the target. This can involve passive activities like monitoring social media, WHOIS databases, or public records to identify potential vulnerabilities and targets.

Entering: In this stage, attackers develop or acquire malicious tools, such as viruses or malware, to exploit the identified vulnerabilities. These tools are often tailored to the specific target and intended to deliver the payload to the victim system

Finding: Attackers deliver the weaponized payload to the target system. This can occur through various means, including phishing emails, infected websites, or other methods that allow the malicious code to be introduced into the target environment.

Exploiting: This stage involves the execution of the malicious payload on the target system. The goal is to take advantage of vulnerabilities in the system to gain unauthorized access or control.

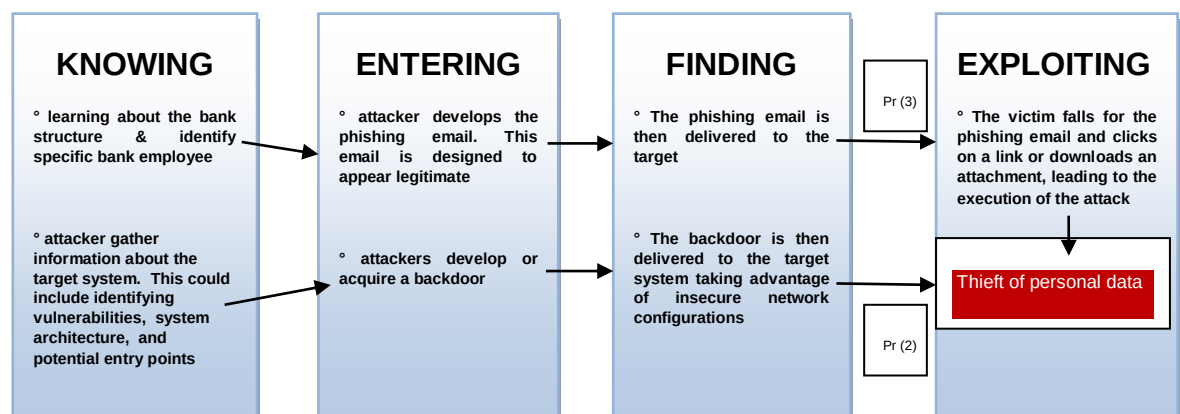
The next graph represents the corresponding operational scenario (of the path 1):



2. Asses the likelihood of operational scenarios

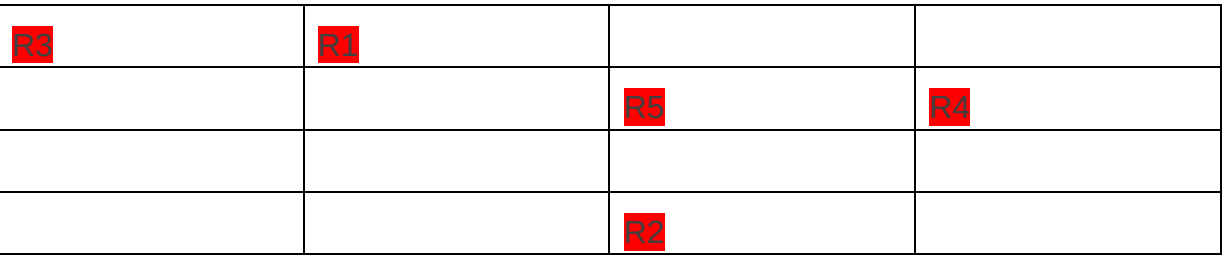
For each operational scenario, how likely is it to occur. We want a table with four levels: unlikely, likely, very likely, and nearly certain to assest each operational scenario. Here's an example of how such a likelihood table could be structured:

Likelihood level	Description
Nearly Certain	The event is almost certain to occur
Very Likely	The event is highly probable.
Likely	The event has a reasonable chance
Unlikely	The event is improbable



Determine the severity and likelihood of each risk scenario.

- R1: Data Breach and Customer Information Compromise
- R2: Distributed Denial of Service (DDoS) Attack
- R3: Insider Threat and Unauthorized Access
- R4: Phishing Attack
- R5: Software Vulnerability Exploitation



How treat the risks :

- R1: Data Breach and Customer Information Compromise (Reduce)
- R2: Distributed Denial of Service (DDoS) Attack (Transfert)
- R3: Insider Threat and Unauthorized Access (Reduce)
- R4: Phishing Attack (Transfert)
- R5: Software Vulnerability Exploitation (Reduce)

What controls to put in place

Control	Risk	Responsible	Timeframe	Status
Business continuity plan	R2	IT departement	4 mois	In progress
.....				

3. Assess residual risks

Residual risk refers to the level of risk that remains after risk mitigation or risk response strategies have been implemented. In the context of risk management, organizations often employ various measures to reduce or eliminate potential threats and vulnerabilities. These measures can include implementing security controls, adopting policies and procedures, and investing in technologies to mitigate the impact or likelihood of adverse events.

